



Unknown Project

Security Assessment Report

2026-04-16

HIGH RISK

110 findings identified

0

CRITICAL

6

HIGH

102

MEDIUM

2

LOW

Disclaimer

Assessment Notice

This security assessment was generated using tachi, an automated threat modeling toolkit. The analysis applies STRIDE methodology and AI-specific threat categories to the provided architecture description. Results reflect the automated analysis and should be validated by qualified security professionals.

Scope Limitation

This assessment is limited to the architecture description provided at the time of analysis. It does not cover runtime behavior, implementation-level vulnerabilities, or threats arising from future system changes. The assessment scope is defined in the Assessment Scope section of this report.

Recommendation

This automated assessment should complement, not replace, manual security review by qualified professionals. Organizations should conduct periodic penetration testing, code review, and architecture review in addition to automated threat modeling.

Confidentiality

This document contains sensitive security assessment information. Distribution should be limited to authorized personnel with a legitimate need to review the security posture of the assessed system. Do not share externally without appropriate authorization.

Table of Contents

Disclaimer 2

Table of Contents 3

Risk Methodology 4

Assessment Scope 8

Executive Summary 13

Executive Threat Architecture 14

Risk Reduction Funnel 29

Risk Summary Dashboard 30

System Architecture 31

MAESTRO Layer Risk Distribution 32

MAESTRO Component-Layer Heatmap 33

MAESTRO Layer Analysis 34

Findings Detail — Residual Risk 44

Control Coverage 64

Remediation Roadmap 65

Risk Methodology

Threat Identification

This assessment uses STRIDE threat modeling combined with AI-specific threat categories to provide comprehensive coverage of both traditional and emerging attack vectors.

STRIDE Categories

Spoofing — Impersonating a user, component, or system to gain unauthorized access.

Tampering — Unauthorized modification of data in transit, at rest, or in processing.

Repudiation — Performing actions without adequate logging or accountability trails.

Information Disclosure — Exposing sensitive data to unauthorized parties through leaks or side channels.

Denial of Service — Degrading or disrupting system availability through resource exhaustion or abuse.

Elevation of Privilege — Gaining higher access rights than authorized through exploitation of trust boundaries.

AI-Specific Categories

Prompt Injection — Manipulating AI model behavior through crafted inputs that override system instructions.

Tool Abuse — Exploiting AI agent tool access to perform unintended or unauthorized operations.

Agent Autonomy — Risks from AI agents acting beyond their intended scope without adequate human oversight.

Data Poisoning — Corrupting training data or context to degrade model accuracy or introduce bias.

Model Theft — Unauthorized extraction or replication of proprietary model weights or behavior.

Probability x Impact Matrix

Each identified threat is assessed for probability of occurrence and potential impact. The intersection determines the overall severity rating used throughout this report.

Impact / Probability	Rare	Unlikely	Possible	Likely	Almost Certain
Critical	H	H	C	C	C
High	M	M	H	C	C
Moderate	L	M	M	H	H
Low	L	L	M	M	H
Negligible	L	L	L	M	M

■ C = Critical ■ H = High ■ M = Medium ■ L = Low

Quantitative Risk Scoring

When quantitative data is available, each threat receives a composite risk score derived from four independent dimensions. This provides a more granular risk ranking than severity alone.

Scoring Dimensions

Dimension	Range	Description
CVSS 3.1 Base Score	0 – 10	Industry-standard vulnerability severity rating based on attack vector, complexity, and impact.
Exploitability	0 – 10	Ease of exploitation considering required skills, tooling availability, and attack complexity.
Scalability	0 – 10	Potential for automated or mass exploitation across multiple targets or instances.
Reachability	0 – 10	Network accessibility of the vulnerable component from the attacker's perspective.

Composite Score Formula

The composite risk score is a weighted average of the four dimensions:

$$\text{Composite} = (\text{CVSS} \times 0.40) + (\text{Exploitability} \times 0.25) + (\text{Scalability} \times 0.20) + (\text{Reachability} \times 0.15)$$

Weights reflect the relative importance of each dimension: CVSS captures inherent severity (40%), exploitability measures practical attack feasibility (25%), scalability accounts for blast radius (20%), and reachability assesses network exposure (15%).

Compensating Control Analysis

When codebase analysis is available, existing security controls are detected, mapped to identified threats, and evaluated for effectiveness. This provides a residual risk assessment that accounts for defenses already in place.

Analysis Process

1. **Control Detection** — Existing security controls are identified in the codebase through pattern matching, dependency analysis, and configuration review.
2. **Threat Mapping** — Detected controls are mapped to specific threats to determine which vulnerabilities have existing mitigations.
3. **Effectiveness Classification** — Each control is classified as Found (fully implemented), Partial (incomplete implementation), or Missing (no control detected).
4. **Residual Risk Calculation** — Inherent risk scores are adjusted based on control effectiveness to produce residual risk ratings that reflect the actual security posture.

Assessment Overview

Assessment Scope

20 Components

45 Data Flows

9 Trust Boundaries

Components Analyzed

Name	Type	Description
Physician	External Entity	External physician user sending clinical queries via HTTPS and receiving recommendation views
Patient	External Entity	External patient providing EHR update events to the ingestion queue
Physician Clinical Portal	Process	Physician-facing web interface and user portal serving the clinical recommendation view; routes queries to Supervisor Orchestrator and enforces RBAC access decisions
Patient Summary Generator	Process	API endpoint generating patient-facing summaries from Supervisor Orchestrator recommendations for consumption by Patient
Inter-Agent Communication Channel	Process	Agent-to-agent message bus relaying delegation messages and specialist results between Supervisor Orchestrator, Diagnostic Agent, and Treatment Planner Agent; logs all inter-agent messages to Clinical Audit Log
Supervisor Orchestrator	Process	Supervisory orchestrator agent directing specialist agents via cascading delegation; produces emergent coordination patterns; dispatches inference to Model Inference API Gateway; writes decision logs to Clinical Audit Log; receives model updates from Outcomes Telemetry
Diagnostic Agent	Process	Autonomous clinical-reasoning executor performing tool dispatch over Clinical MCP Tool Server; coordinates with Treatment Planner Agent via Inter-Agent Communication Channel; queries Clinical Guideline RAG Corpus; requests risk inference via Model Inference API Gateway
Treatment Planner Agent	Process	Autonomous treatment-planning agent joining Supervisor-delegated tasks via Inter-Agent Communication Channel; queries Medical Literature Vector Index; dispatches tool calls via Clinical MCP Tool Server
Clinical MCP Tool Server	Process	MCP Tool Server providing JSON-RPC tool calls to Diagnostic Agent and Treatment Planner Agent; performs FHIR read/write on FHIR Resource Store
Clinical LLM	Process	Foundation language model inference endpoint for clinical reasoning; frozen base model with prompt-based adaptation; receives completion requests forwarded by Model Inference API Gateway
Risk Stratification Model	Process	Fine-tuned language model for patient risk stratification; foundation model adapted via supervised fine-tuning on de-identified historical cohorts; exposes an inference engine endpoint via Model Inference API Gateway
FHIR Resource Store	Data Store	Clinical FHIR resource database and cache storing structured patient records; accessed by Supervisor Orchestrator and Clinical MCP Tool Server; PHI read/write gated by Consent and De-identification Guardrail
Clinical Guideline RAG Corpus	Data Store	Retrieval-augmented generation corpus of clinical practice guidelines with dense embeddings and a vector store for semantic retrieval; queried by Diagnostic Agent

Name	Type	Description
Medical Literature Vector Index	Data Store	Vector index of medical literature for semantic retrieval by Treatment Planner Agent
Model Inference API Gateway	Process	API gateway container fronting the Clinical LLM and Risk Stratification Model inference endpoints; forwards inference requests from Supervisor Orchestrator and Diagnostic Agent
EHR Ingestion Queue	Data Store	Queue buffering EHR update events from Patient before normalization into FHIR Resource Store
Clinical Audit Log	Data Store	Audit log receiving decision log entries from Supervisor Orchestrator, Diagnostic Agent, Treatment Planner Agent, and Inter-Agent Communication Channel; feeds Outcomes Telemetry observability stream
Outcomes Telemetry and Physician Override Audit Store	Data Store	Long-running learning loop and feedback loop carrier for continual learning against physician-override telemetry; monitors outcome drift; feeds periodic model update re-training signals to Supervisor Orchestrator and Clinical LLM
HIPAA RBAC + Policy Engine	Process	RBAC and policy engine enforcing HIPAA access control; issues access decisions to Physician Clinical Portal and compliance check decisions to Supervisor Orchestrator; logs policy events to Clinical Audit Log
Consent and De-identification Guardrail	Process	Guardrail enforcing patient consent and de-identification with encryption controls on PHI read/write paths on FHIR Resource Store

Data Flows

Source	Destination	Data	Protocol
Physician	Physician Clinical Portal	Clinical query	HTTPS
Physician Clinical Portal	Supervisor Orchestrator	Authenticated clinical intent	Internal API
Supervisor Orchestrator	Physician Clinical Portal	Clinical recommendation response	Internal API
Physician Clinical Portal	Physician	Recommendation view	HTTPS
Patient	EHR Ingestion Queue	EHR update event	Internal
EHR Ingestion Queue	FHIR Resource Store	Normalized patient record	Internal
FHIR Resource Store	Supervisor Orchestrator	Clinical context retrieval	Internal
Supervisor Orchestrator	Inter-Agent Communication Channel	Delegation message (cross-agent coordinate)	Internal
Inter-Agent Communication Channel	Diagnostic Agent	Delegated diagnostic task (inter-agent coordinate)	Internal

Source	Destination	Data	Protocol
Diagnostic Agent	Inter-Agent Communication Channel	Specialist diagnostic result (joint reasoning)	Internal
Inter-Agent Communication Channel	Treatment Planner Agent	Delegated treatment task (inter-agent coordinate)	Internal
Treatment Planner Agent	Inter-Agent Communication Channel	Treatment plan (joint reasoning)	Internal
Inter-Agent Communication Channel	Supervisor Orchestrator	Aggregated specialist output	Internal
Supervisor Orchestrator	Model Inference API Gateway	Inference request	Internal
Model Inference API Gateway	Clinical LLM	Inference request forwarded	Internal
Clinical LLM	Model Inference API Gateway	Completion	Internal
Model Inference API Gateway	Supervisor Orchestrator	Completion forwarded	Internal
Diagnostic Agent	Model Inference API Gateway	Risk inference request	Internal
Model Inference API Gateway	Risk Stratification Model	Risk inference request	Internal
Risk Stratification Model	Model Inference API Gateway	Stratification output	Internal
Model Inference API Gateway	Diagnostic Agent	Stratification output	Internal
Diagnostic Agent	Clinical Guideline RAG Corpus	Guideline retrieval query	Internal
Clinical Guideline RAG Corpus	Diagnostic Agent	Retrieved guidelines	Internal
Treatment Planner Agent	Medical Literature Vector Index	Literature retrieval query	Internal
Medical Literature Vector Index	Treatment Planner Agent	Retrieved literature	Internal
Diagnostic Agent	Clinical MCP Tool Server	Tool call (JSON-RPC)	JSON-RPC
Treatment Planner Agent	Clinical MCP Tool Server	Tool call (JSON-RPC)	JSON-RPC
Clinical MCP Tool Server	Diagnostic Agent	Tool result	Internal

Source	Destination	Data	Protocol
Clinical MCP Tool Server	Treatment Planner Agent	Tool result	Internal
Clinical MCP Tool Server	FHIR Resource Store	FHIR read/write	Internal
Physician Clinical Portal	HIPAA RBAC + Policy Engine	Access request	Internal
HIPAA RBAC + Policy Engine	Physician Clinical Portal	Access decision	Internal
Supervisor Orchestrator	HIPAA RBAC + Policy Engine	Compliance check	Internal
FHIR Resource Store	Consent and De-identification Guardrail	PHI read/write	Internal
Consent and De-identification Guardrail	FHIR Resource Store	De-identified PHI	Internal
Supervisor Orchestrator	Clinical Audit Log	Decision log entry	Internal
Diagnostic Agent	Clinical Audit Log	Decision log entry	Internal
Treatment Planner Agent	Clinical Audit Log	Decision log entry	Internal
Inter-Agent Communication Channel	Clinical Audit Log	Inter-agent message log	Internal
HIPAA RBAC + Policy Engine	Clinical Audit Log	Policy event log	Internal
Clinical Audit Log	Outcomes Telemetry and Physician Override Audit Store	Observability stream	Internal
Outcomes Telemetry and Physician Override Audit Store	Supervisor Orchestrator	Periodic model update (learning loop re-training)	Internal
Outcomes Telemetry and Physician Override Audit Store	Clinical LLM	Periodic model update (feedback loop drift correction)	Internal
Supervisor Orchestrator	Patient Summary Generator	Summary request	Internal
Patient Summary Generator	Patient	Patient-facing summary	HTTPS

Trust Boundaries

Zone	Trust Level	Components
External Zone	Untrusted	Physician, Patient
User Interface Zone (L7)	Semi-Trusted	Physician Clinical Portal, Patient Summary Generator
Agent Ecosystem Zone (L7)	Semi-Trusted	Inter-Agent Communication Channel
Agent Frameworks Zone (L3)	Trusted	Supervisor Orchestrator, Diagnostic Agent, Treatment Planner Agent, Clinical MCP Tool Server
Foundation Models Zone (L1)	Trusted	Clinical LLM, Risk Stratification Model
Data Operations Zone (L2)	Trusted	FHIR Resource Store, Clinical Guideline RAG Corpus, Medical Literature Vector Index
Deployment Infrastructure Zone (L4)	Trusted	Model Inference API Gateway, EHR Ingestion Queue
Evaluation and Observability Zone (L5)	Trusted	Clinical Audit Log, Outcomes Telemetry and Physician Override Audit Store
Security and Compliance Zone (L6)	Trusted	HIPAA RBAC + Policy Engine, Consent and De-identification Guardrail

Executive Summary

Severity Distribution

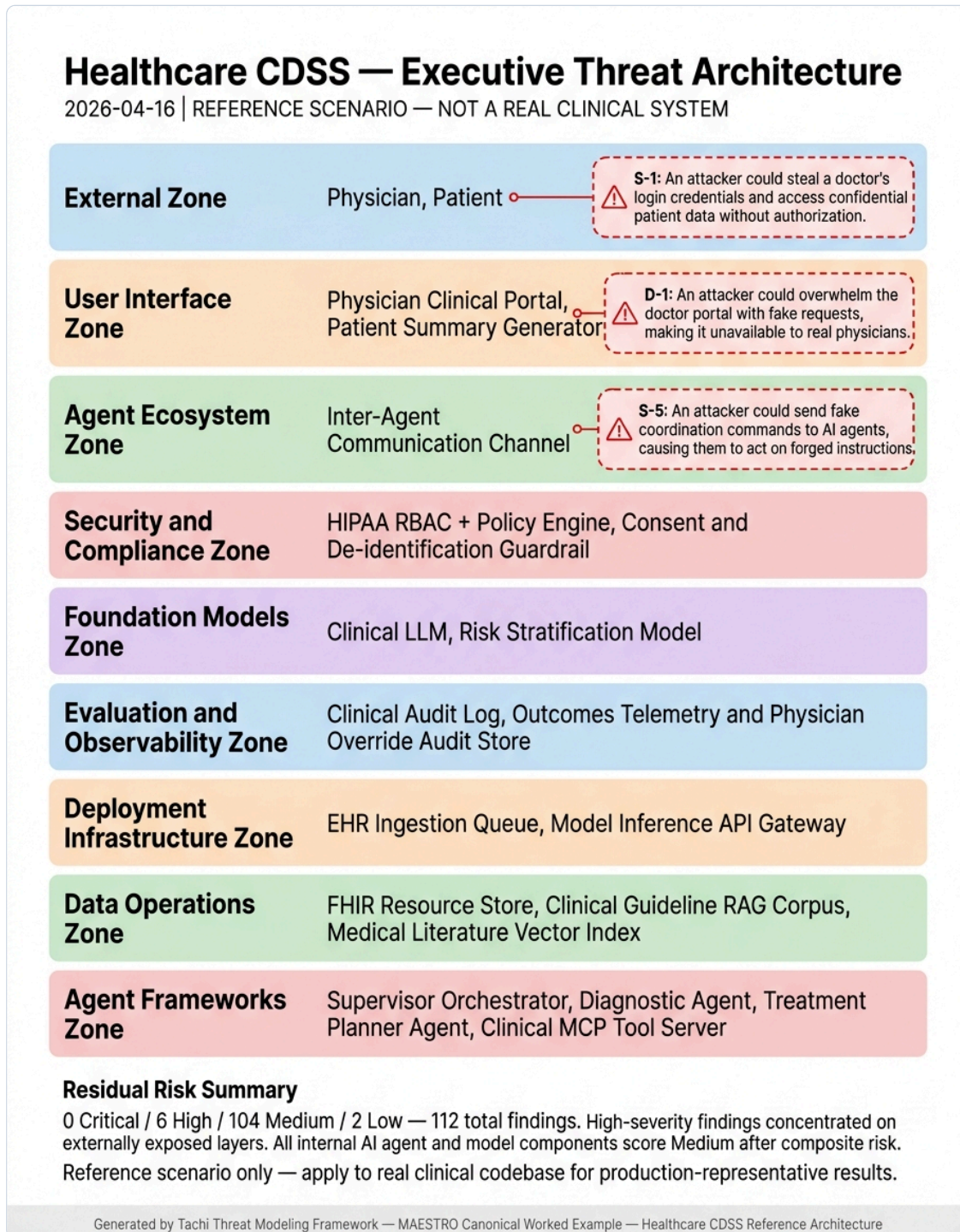
110 findings total



Component Distribution

Component	Findings
Clinical LLM	9
Risk Stratification Model	9
Supervisor Orchestrator	9
Diagnostic Agent	8
Inter-Agent Communication Channel	8
Treatment Planner Agent	8
Clinical MCP Tool Server	7
HIPAA RBAC + Policy Engine	6
Model Inference API Gateway	6
Patient Summary Generator	6
Physician Clinical Portal	6
Consent and De-identification Guardrail	5
Outcomes Telemetry and Physician Override Audit Store	4
Clinical Audit Log	3
Clinical Guideline RAG Corpus	3
EHR Ingestion Queue	3
FHIR Resource Store	3
Medical Literature Vector Index	3
Patient	2
Physician	2

Executive Threat Architecture



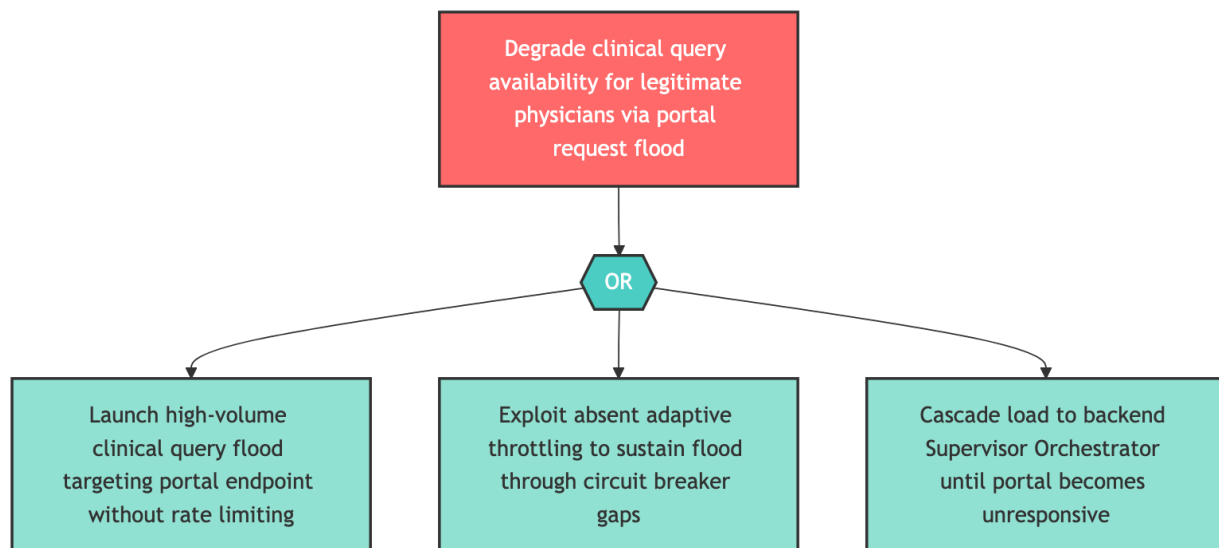
Layered system architecture with critical and high severity threats annotated as narrative callouts. This visualization highlights where the most exposed components sit in the system and what kind of attack each layer is most vulnerable to.

Attack Path Analysis

Attack Path Analysis

HIGH D-1 – Physician Clinical Portal Clinical Query Flood

Component: Physician Clinical Portal



An attacker targets Physician Clinical Portal by attempting to degrade clinical query availability for legitimate physicians via portal request flood. The attack proceeds through any of several attack paths. Required attacker actions include "Launch high-volume clinical query flood targeting portal endpoint without rate limiting", "Exploit absent adaptive throttling to sustain flood through circuit breaker gaps", "Cascade load to backend Supervisor Orchestrator until portal becomes unresponsive".

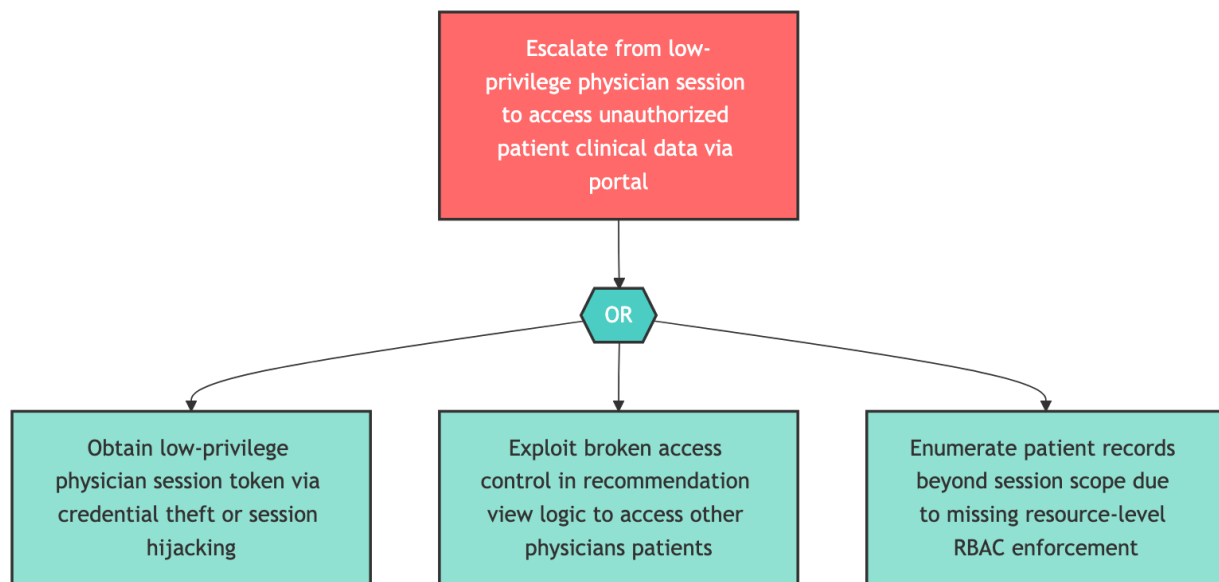
Remediation Steps

- Implement request rate limiting on the physician clinical portal API endpoints.
- Configure a per-IP and per-session rate limiter with thresholds calibrated to expected clinical usage patterns.
- Add a circuit breaker wrapping the downstream CDSS orchestration layer to prevent cascade failures under load.

Attack Path Analysis

HIGH E-1 — Physician Clinical Portal Privilege Escalation

Component: Physician Clinical Portal



An attacker targets Physician Clinical Portal by attempting to escalate from low-privilege physician session to access unauthorized patient clinical data via portal. The attack proceeds through any of several attack paths. Required attacker actions include "Obtain low-privilege physician session token via credential theft or session hijacking", "Exploit broken access control in recommendation view logic to access other physicians patients", "Enumerate patient records beyond session scope due to missing resource-level RBAC enforcement".

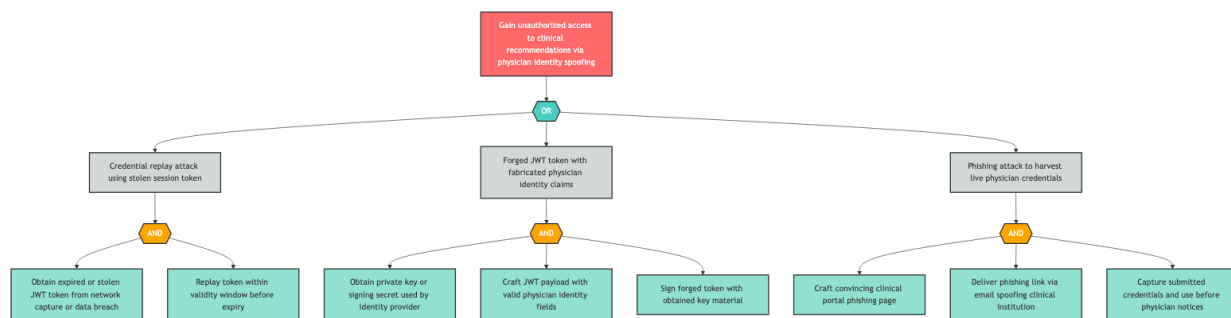
Remediation Steps

- Implement role-based access control (RBAC) enforcing per-physician data scope on all portal data retrieval endpoints.
- Add resource ownership validation that prevents horizontal privilege escalation to other physicians' or patients' data.
- Every data fetch endpoint must assert that the requesting session's physician ID matches the requested resource scope.

Attack Path Analysis

HIGH S-1 — Physician Identity Spoofing

Component: Physician



An attacker targets Physician by attempting to gain unauthorized access to clinical recommendations via physician identity spoofing. The attack proceeds through combinations of several attack paths. Required attacker actions include "Obtain expired or stolen JWT token from network capture or data breach", "Replay token within validity window before expiry", "Obtain private key or signing secret used by identity provider", and 5 additional actions.

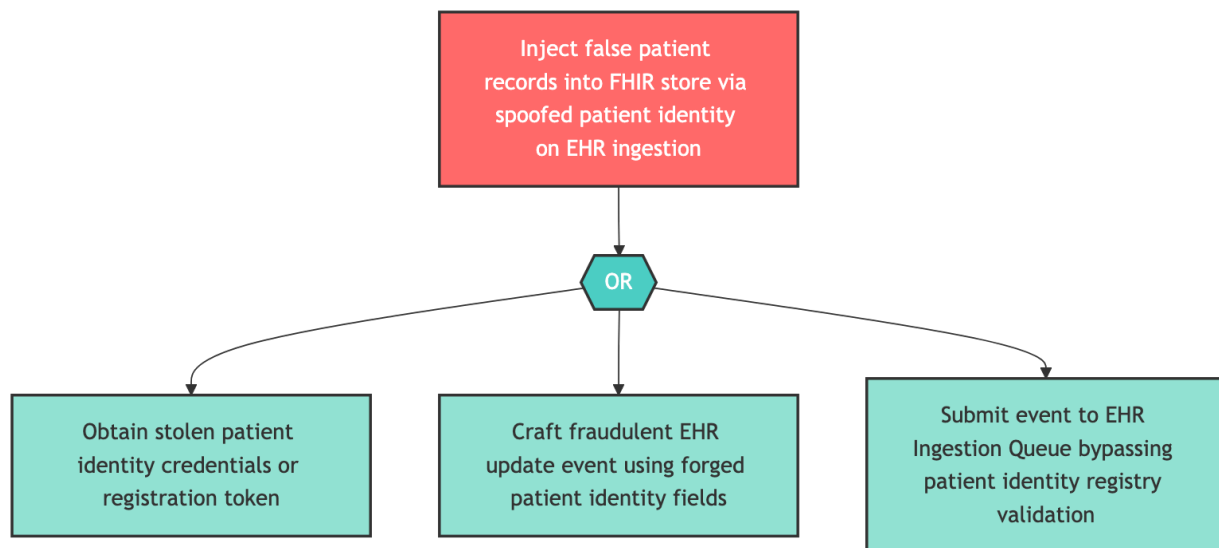
Remediation Steps

- Implement multi-factor authentication (MFA) and credential replay protection for the physician authentication endpoint.
- Deploy a short-lived JWT or OAuth 2.0 token scheme with cryptographic binding to session context.
- Add token replay detection using a nonce or jti claim validated against a server-side token store.

Attack Path Analysis

HIGH S-2 — Patient Identity Spoofing for EHR Injection

Component: Patient



An attacker targets Patient by attempting to inject false patient records into fhir store via spoofed patient identity on ehr ingestion. The attack proceeds through any of several attack paths. Required attacker actions include "Obtain stolen patient identity credentials or registration token", "Craft fraudulent EHR update event using forged patient identity fields", "Submit event to EHR Ingestion Queue bypassing patient identity registry validation".

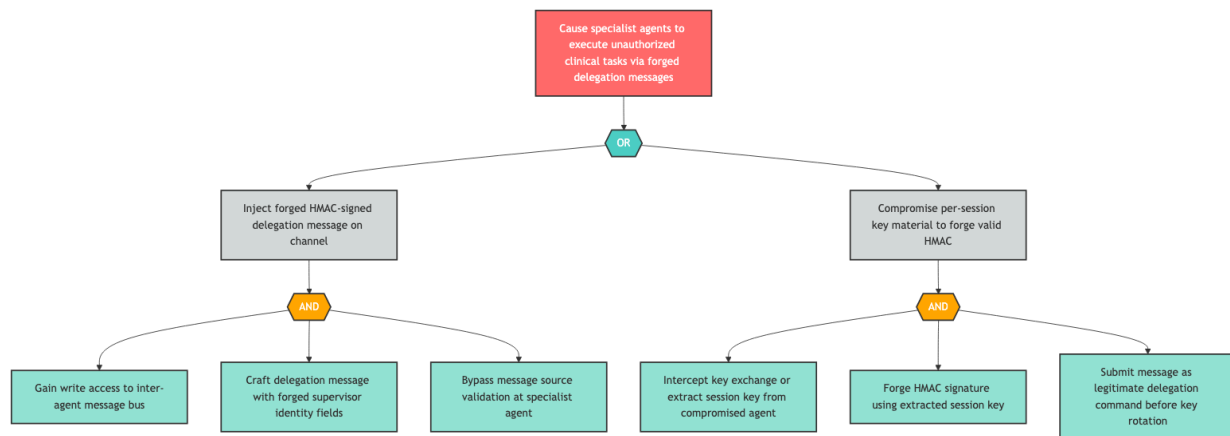
Remediation Steps

- Implement patient identity verification with signed event envelopes on the EHR ingestion endpoint.
- Each incoming EHR update event should carry a verifiable patient identity token (e.g., SMART on FHIR patient context) and a message authentication code preventing tampering.
- Deploy input schema validation to reject malformed or unexpected event structures.

Attack Path Analysis

HIGH S-5 — Inter-Agent Channel Supervisor Delegation Spoofing

Component: Inter-Agent Communication Channel



An attacker targets Inter-Agent Communication Channel by attempting to cause specialist agents to execute unauthorized clinical tasks via forged delegation messages. The attack proceeds through combinations of several attack paths. Required attacker actions include "Gain write access to inter-agent message bus", "Craft delegation message with forged supervisor identity fields", "Bypass message source validation at specialist agent", and 3 additional actions.

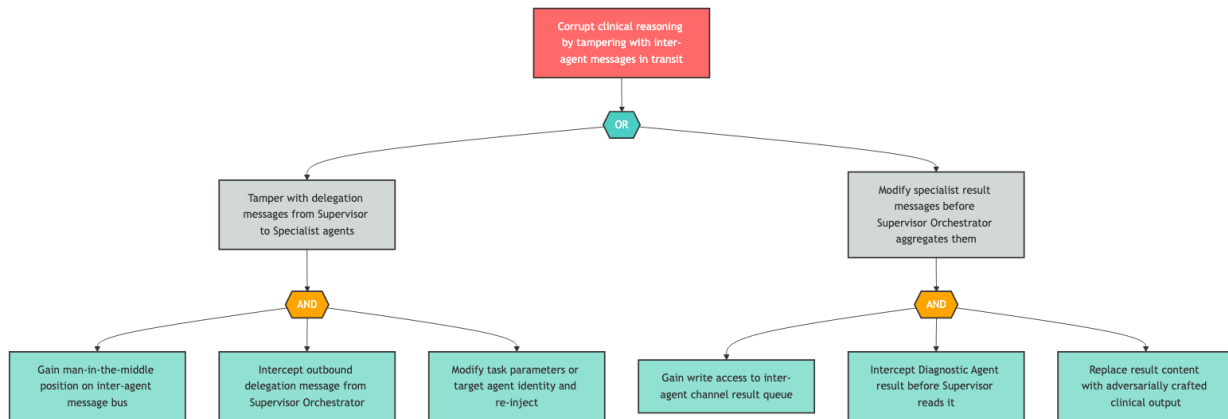
Remediation Steps

- Implement message authentication on the inter-agent communication channel.
- Each delegation message must carry a cryptographic signature from the originating supervisor agent, verified by the receiving specialist agent before execution.
- Use a shared asymmetric key infrastructure where the supervisor holds the private signing key and specialist agents hold the corresponding verification key.

Attack Path Analysis

HIGH T-3 — Inter-Agent Channel Message Tampering

Component: Inter-Agent Communication Channel



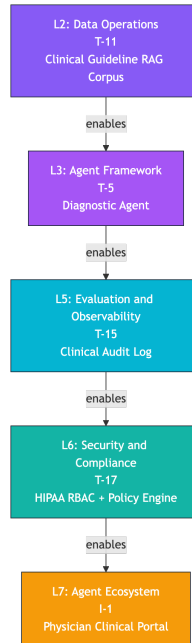
An attacker targets Inter-Agent Communication Channel by attempting to corrupt clinical reasoning by tampering with inter-agent messages in transit. The attack proceeds through combinations of several attack paths. Required attacker actions include "Gain man-in-the-middle position on inter-agent message bus", "Intercept outbound delegation message from Supervisor Orchestrator", "Modify task parameters or target agent identity and re-inject", and 3 additional actions.

Remediation Steps

- Implement message integrity protection on all inter-agent delegation messages and specialist results.
- Encrypt the message bus channel using TLS with mutual authentication, and add per-message HMAC integrity tokens that detect tampering in transit.
- Log all message integrity failures to the clinical audit log.

Cross-Layer Attack Chain Analysis

Cross-Layer Attack Chain Analysis

CRITICAL CHAIN-001 L2 → L3 → L5 → L6 → L7 **RAG Corpus Poisoning to False Clinical Recommendation via Agent Hijack**


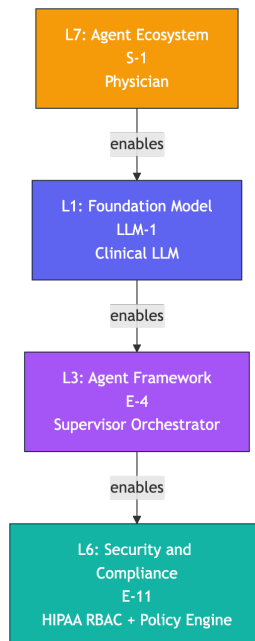
Attack Progression

An adversary initiates the chain by injecting adversarially crafted embeddings into the Clinical Guideline RAG Corpus (L2 — Data Operations). This poisoning attack corrupts the retrieval index with malicious clinical guidance documents that appear legitimate but encode attacker-preferred diagnostic recommendations. The RAG corpus lies upstream of all Diagnostic Agent guideline lookups and is unauthenticated for provenance at the embedding level. The corrupted corpus triggers manipulation of Diagnostic Agent (L3 — Agent Framework) tool call behavior. When the Diagnostic Agent issues a guideline retrieval query, the poisoned corpus surfaces adversarial guidance, which the agent incorporates into its tool call parameters and specialist diagnostic outputs forwarded through the Inter-Agent Communication Channel. The agent's decision-making is subverted without any individual component being overtly compromised. The compromised diagnostic output enables Clinical Audit Log (L5 — Evaluation and Observability) tampering. An attacker aware of the attack progression covers tracks by suppressing or modifying the Diagnostic Agent's decision log entries before they propagate to the Outcomes Telemetry store, eliminating the forensic trail of the poisoning event. The audit trail suppression enables HIPAA RBAC + Policy Engine (L6 — Security and Compliance) policy tampering. Without a complete audit trail, anomalous access patterns associated with the attack are not flagged, allowing the attacker to modify RBAC policies to grant elevated access to the compromised clinical workflow. Finally, the compounded upstream manipulations manifest as false clinical recommendation disclosure at the Physician Clinical Portal (L7 — Agent Ecosystem) — a physician receives a recommendation grounded in adversarial guidelines, presented with full apparent clinical authority.

Remediating T-15 (Clinical Audit Log tampering — the intermediate cascade at L5) would disconnect the upstream diagnostic chain from the downstream security control bypass, as the audit suppression is the structural link enabling the L6 RBAC manipulation.

Impacted Findings: T-11, T-5, T-15, T-17, I-1

Cross-Layer Attack Chain Analysis

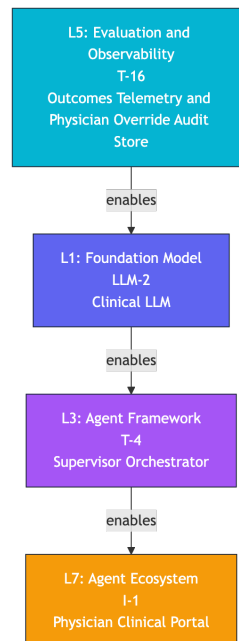
CRITICAL CHAIN-002 L7 → L1 → L3 → L6 **Prompt Injection to Orchestrator
Privilege Escalation via Foundation Model**


Attack Progression

The chain initiates at the Agent Ecosystem boundary (L7) where an attacker spoofs a legitimate physician identity to gain authenticated access to the Physician Clinical Portal. The spoofed session carries valid-appearing credentials that bypass initial authentication gates, establishing a foothold in the clinical query pipeline under a trusted physician identity. The spoofed physician session shifts the attack surface to the Foundation Model layer (L1), where the attacker crafts malicious clinical queries containing adversarial prompt injection payloads embedded within the apparent clinical question. When forwarded through the API Gateway to the Clinical LLM, the injected instructions direct the model to emit completions containing embedded system commands or escalated instruction patterns that the Supervisor Orchestrator's prompt parser may interpret as trusted control signals. The manipulated LLM completion enables Supervisor Orchestrator privilege escalation (L3 — Agent Framework). The orchestrator, receiving a completion that appears to originate from the trusted Clinical LLM inference endpoint, may execute embedded instructions that bypass its own RBAC compliance check logic, effectively granting the attacker's session elevated orchestration authority — including the ability to issue delegation commands beyond the spoofed physician's authorized scope. The orchestrator privilege escalation manifests as HIPAA RBAC + Policy Engine administrative compromise (L6 — Security and Compliance), where the now-escalated orchestrator session is used to modify RBAC policies or exploit the policy engine's trust in the orchestrator service account, creating durable unauthorized access. Remediating LLM-1 (prompt injection at L1 — the first intermediate cascade) breaks the chain by preventing the foundation model layer from converting the spoofed credential into an escalation payload.

Impacted Findings: S-1, LLM-1, E-4, E-11

Cross-Layer Attack Chain Analysis

CRITICAL CHAIN-003 L5 → L1 → L3 → L7 **Outcomes Telemetry Tampering to Model Drift via Learning Loop**


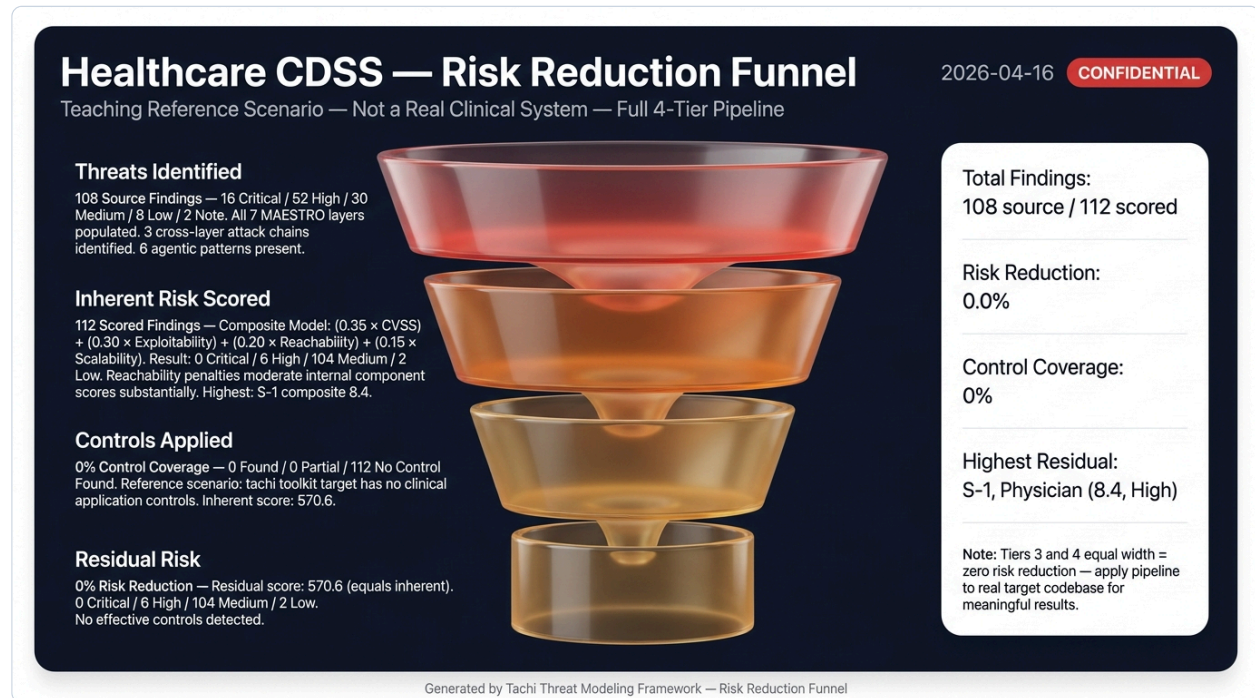
Attack Progression

The attack initiates at the Evaluation and Observability layer (L5) by tampering with the Outcomes Telemetry and Physician Override Audit Store. An adversary with write access to this store injects adversarially crafted physician-override signals — false feedback indicating that certain high-risk clinical recommendations were endorsed by physicians when they were not. This telemetry store is the primary feedback channel for the long-running learning loop that drives continual model re-training. The corrupted telemetry triggers data poisoning of the Clinical LLM (L1 — Foundation Model) during the next scheduled learning loop re-training cycle. The adversarial physician-override signals are incorporated as positive training examples, causing the model to drift toward systematically producing the attacker's preferred clinical outputs for specific patient presentations — a temporal attack that may not surface until weeks after the initial telemetry injection. The model drift enables Supervisor Orchestrator tampering (L3 — Agent Framework), where the corrupted Clinical LLM now returns biased completions that cause the orchestrator's aggregation logic to synthesize clinical recommendations that favor the attacker's preferred outcomes. The orchestrator's delegation decisions are themselves corrupted because the foundation model completion that informs them has been systematically shifted. The compounded corruption manifests as false clinical recommendation disclosure at the Physician Clinical Portal (L7 — Agent Ecosystem), where physicians receive systematically biased recommendations for specific patient cohorts — recommendations grounded in adversarially shifted model behavior that is indistinguishable from legitimate clinical AI output. Remediating T-16 (Outcomes Telemetry tampering at L5 — the initial

exploit) prevents the adversarial signals from ever reaching the learning loop, breaking the entire chain at its source before the model layer is affected.

Impacted Findings: T-16, LLM-2, T-4, I-1

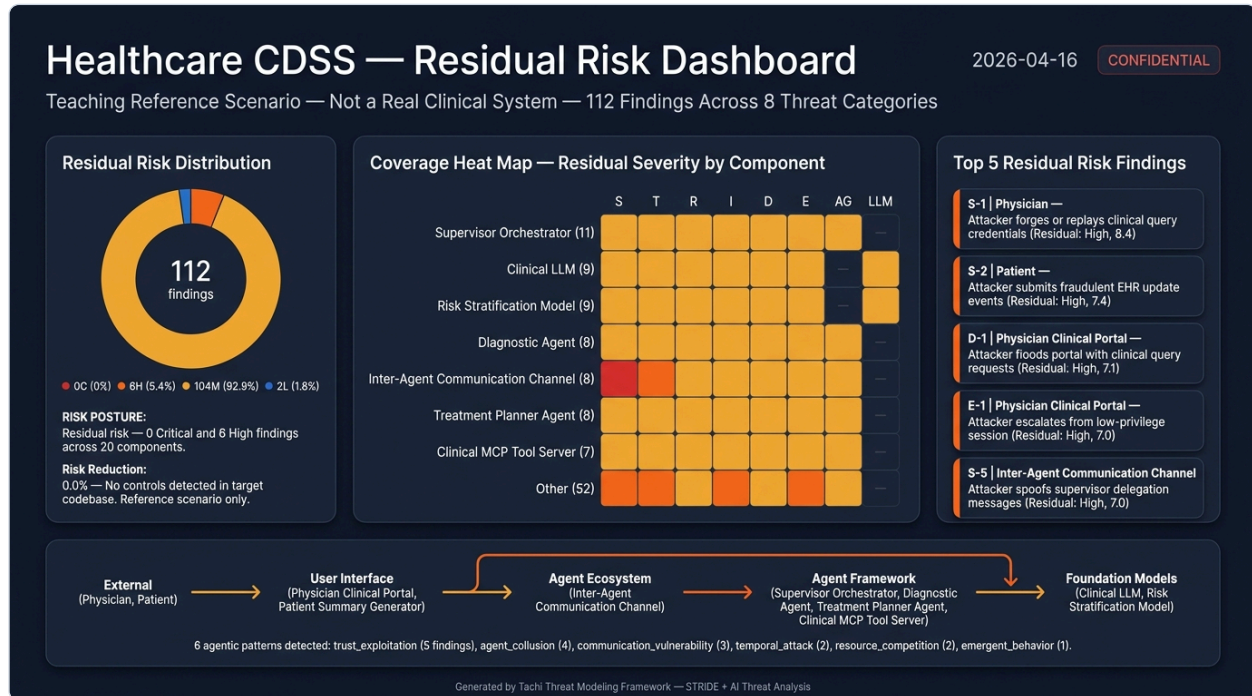
Risk Reduction Funnel



The Risk Reduction Funnel illustrates how the overall risk profile transforms through each stage of the assessment pipeline. The top tier shows all threats identified during the initial STRIDE and AI-specific threat analysis. The second tier reflects severity recalibration after quantitative scoring, where composite scores incorporating CVSS, exploitability, scalability, and reachability may shift initial severity ratings.

The third tier shows the impact of compensating controls detected in the codebase — existing mitigations that reduce effective risk. The bottom tier presents the final residual risk posture, representing the organization's actual exposure after accounting for all identified defenses. The sidebar provides key metrics at a glance, including the total risk reduction percentage, control coverage rate, and the highest-residual-risk finding requiring priority attention.

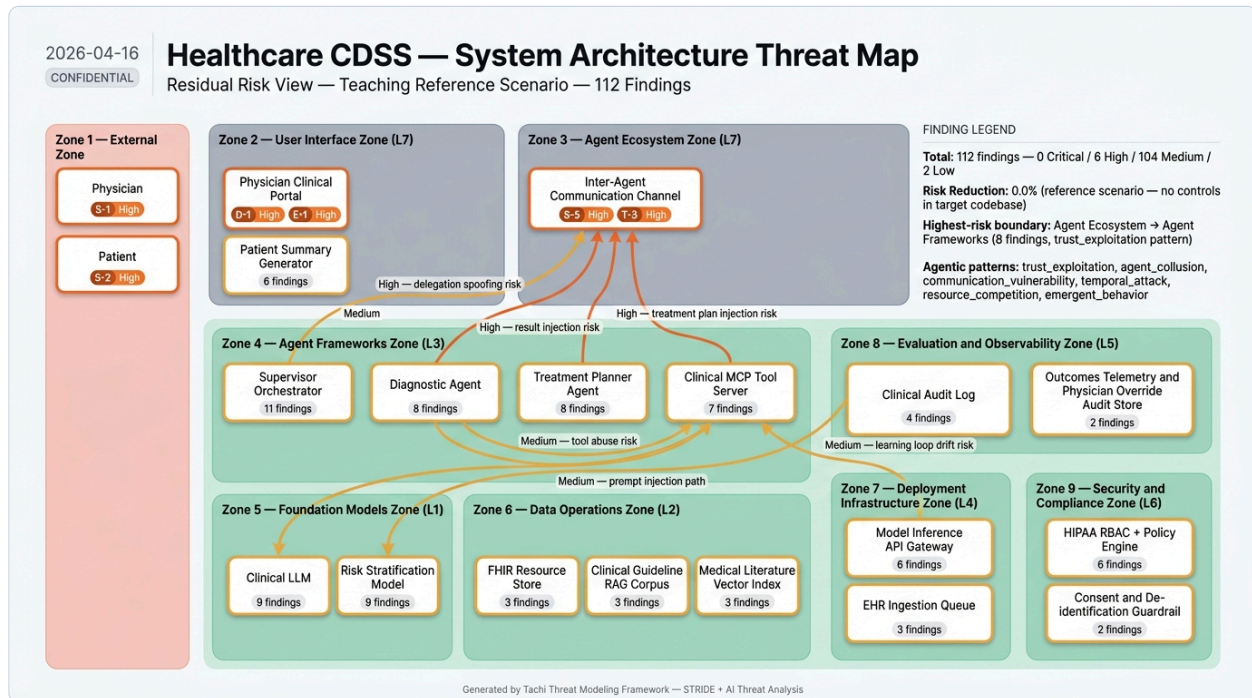
Risk Summary Dashboard



The Risk Summary Dashboard consolidates assessment results into three complementary views. The left panel displays the residual risk distribution across severity levels, showing how findings are distributed after compensating controls are applied.

The center panel presents a component-by-threat-category heat map, where each cell indicates the highest residual severity for that intersection of system component and STRIDE or AI threat category. This enables rapid identification of which components carry the highest concentration of risk. The right panel highlights the top findings by residual risk score, listing the specific threats that require the most immediate attention with their affected components and residual scores.

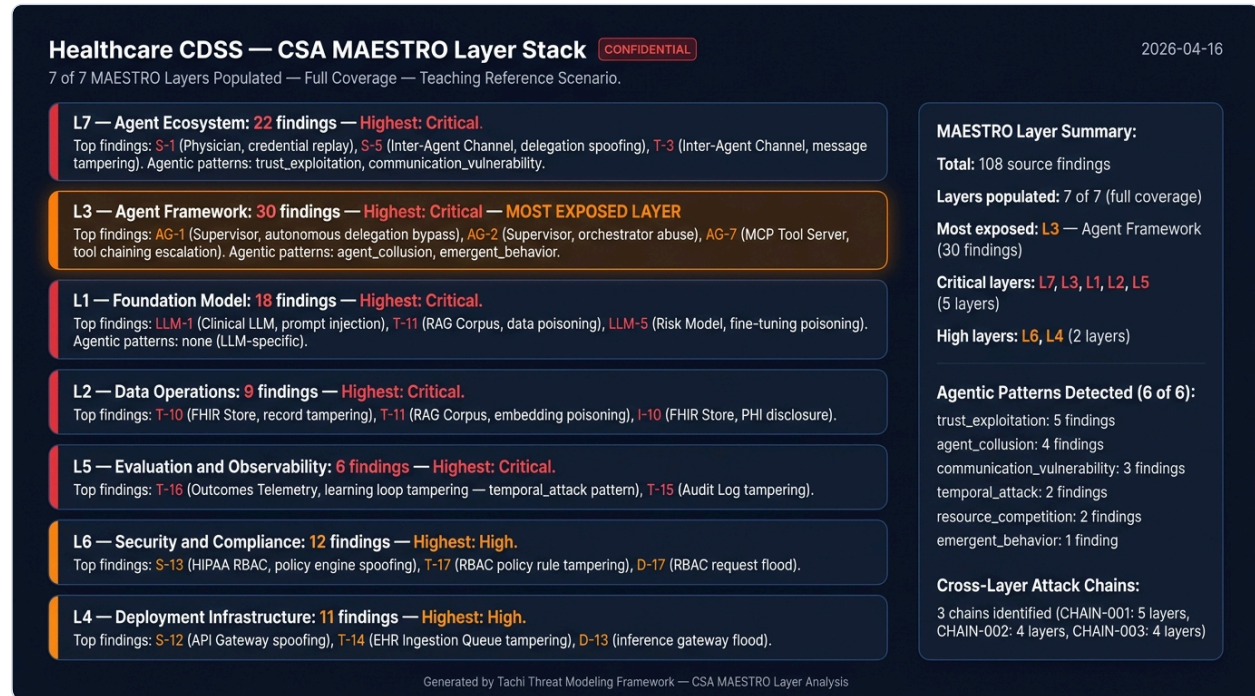
System Architecture



The System Architecture diagram maps identified threats directly onto the assessed system's component topology. Components are grouped within their trust boundaries — external/untrusted, application layer, and infrastructure/platform zones — with color coding reflecting the concentration and severity of findings at each location.

Threat badges on each component show the specific threat identifiers and their severity classifications. Data flow arrows illustrate the assessed communication paths between components, with trust boundary crossings highlighted as key attack surface areas where threats are most likely to be exploited. This spatial view complements the tabular findings detail by showing how threats cluster around specific architectural chokepoints.

MAESTRO Layer Risk Distribution



The MAESTRO Layer Risk Distribution diagram maps identified threats onto the seven-layer CSA MAESTRO framework for agentic AI systems. Each horizontal band represents an architectural layer from Foundation Model (L1) through Agent Ecosystem (L7), showing the finding count and highest severity at each layer. The most-exposed layer is visually highlighted.

This view enables security leaders to quickly identify which architectural layers of the AI stack carry the most risk exposure and prioritize remediation efforts accordingly.

MAESTRO Component-Layer Heatmap



The MAESTRO Component-Layer Heatmap provides a granular view of how threats intersect specific system components with MAESTRO architectural layers. Each cell represents the highest-severity finding at the intersection of a component (row) and a MAESTRO layer (column).

This cross-tabulation identifies specific component-layer hotspots that require targeted remediation, complementing the aggregate layer view in the MAESTRO Stack diagram.

MAESTRO Layer Analysis

MAESTRO Layer Analysis

The following findings are grouped by their CSA MAESTRO framework architectural layer, providing a layer-oriented view of the threat landscape. Each layer represents a distinct level of the agentic AI system stack, from Foundation Model (L1) through Agent Ecosystem (L7). Findings within each layer are sorted by severity.

L1 — Foundation Model (18 findings)

ID	Component	Severity	Threat
LLM-1	Clinical LLM	CRITICAL	An attacker may inject adversarial prompts into the clinical context window passed to the Clinical LLM via the API Gateway, causing the model to generate harmful, false, or clinically dangerous completions that the Supervisor Orchestrator incorporates into clinical recommendations.
T-8	Clinical LLM	HIGH	An attacker may tamper with the Clinical LLM prompt inputs forwarded by the API Gateway, injecting adversarial tokens that corrupt the clinical reasoning completion.
T-9	Risk Stratification Model	HIGH	An attacker may tamper with fine-tuning data or inference inputs to the Risk Stratification Model, causing systematically biased risk scores that lead to incorrect clinical decisions.
I-8	Clinical LLM	HIGH	The Clinical LLM may memorize and surface sensitive training data including patient records in its completions, disclosing PHI to agents that did not have authorization to access it.
I-9	Risk Stratification Model	HIGH	The Risk Stratification Model may leak patient cohort data from its fine-tuning training set through membership inference attacks or through overfitted responses that reveal individual patient characteristics.
D-8	Clinical LLM	HIGH	An attacker may exhaust Clinical LLM inference capacity through large prompt floods via the API Gateway, preventing legitimate clinical reasoning requests from being served.
E-8	Clinical LLM	HIGH	An attacker may exploit prompt injection in the Clinical LLM to gain elevated reasoning authority, causing the model to output instructions that the Supervisor Orchestrator interprets as authorized system commands with elevated privilege.
LLM-2	Clinical LLM	HIGH	An adversary may poison the training data or fine-tuning feedback incorporated into the Clinical LLM via the Outcomes Telemetry learning loop, causing the model to produce systematically biased or manipulated clinical completions after re-training.
LLM-4	Risk Stratification Model	HIGH	An attacker may craft adversarial patient record inputs passed to the Risk Stratification Model to generate

			manipulated risk scores, causing incorrect clinical triage and resource allocation decisions.
LLM-5	Risk Stratification Model	HIGH	An adversary may poison the supervised fine-tuning dataset used to train the Risk Stratification Model, embedding adversarial patterns that cause the model to systematically misclassify high-risk patients as low-risk after re-training.
LLM-6	Risk Stratification Model	HIGH	An adversary may conduct membership inference attacks against the Risk Stratification Model to determine which patients were included in the fine-tuning dataset, violating patient privacy even when the model is deployed without direct data access.
S-10	Clinical LLM	MEDIUM	An attacker may spoof Clinical LLM completion responses by intercepting the API Gateway channel, returning fabricated clinical reasoning outputs.
S-11	Risk Stratification Model	MEDIUM	An attacker may spoof Risk Stratification Model outputs to inject false risk stratification results, causing the Diagnostic Agent to base decisions on falsified patient risk levels.
R-10	Clinical LLM	MEDIUM	The Clinical LLM may fail to maintain non-repudiable logs of which prompts were submitted and which completions were returned, making it impossible to audit the basis of clinical reasoning outputs.
R-11	Risk Stratification Model	MEDIUM	The Risk Stratification Model may fail to maintain non-repudiable records of which patient inputs produced which risk scores, preventing audit of risk stratification decisions.
D-9	Risk Stratification Model	MEDIUM	An attacker may target the Risk Stratification Model with high-volume risk inference requests, saturating the model's inference capacity and degrading diagnostic availability.
E-9	Risk Stratification Model	MEDIUM	An attacker may manipulate Risk Stratification Model inputs to produce falsely elevated risk scores that trigger automated escalation workflows, gaining access to high-privilege clinical interventions.
LLM-3	Clinical LLM	LOW	An adversary may extract the Clinical LLM's learned clinical knowledge through repeated targeted queries via the API Gateway, enabling model theft or reconstruction of proprietary medical AI capabilities.

L2 — Data Operations (9 findings)

ID	Component	Severity	Threat
T-10	FHIR Resource Store	CRITICAL	An attacker with access to the FHIR Resource Store may tamper with patient records, injecting false clinical data that corrupts all downstream clinical decision processes.
T-11	Clinical Guideline RAG Corpus	CRITICAL	An attacker may poison the Clinical Guideline RAG Corpus by injecting adversarially crafted guideline embeddings, causing the RAG retrieval to surface malicious clinical guidance to the Diagnostic Agent.
I-10	FHIR Resource Store	CRITICAL	Patient PHI stored in the FHIR Resource Store may be disclosed through unauthorized read operations by agents with overly broad access, SQL/FHIR injection attacks, or missing PHI encryption at rest.
T-12	Medical Literature Vector Index	HIGH	An attacker may inject malicious vector embeddings into the Medical Literature Vector Index, causing Treatment Planner Agent to retrieve and incorporate adversarial literature recommendations.
D-10	FHIR Resource Store	HIGH	An attacker may execute resource-exhausting FHIR queries or write floods against the FHIR Resource Store, degrading

			availability for all components dependent on patient record retrieval.
I-11	Clinical Guideline RAG Corpus	LOW	The Clinical Guideline RAG Corpus may inadvertently index sensitive patient data if clinical guidelines incorporate patient examples, disclosing this data through semantic retrieval to the Diagnostic Agent.
I-12	Medical Literature Vector Index	LOW	The Medical Literature Vector Index may expose sensitive research data or cross-contaminate patient-specific retrieval results if insufficient session isolation is implemented.
D-11	Clinical Guideline RAG Corpus	LOW	An attacker may issue retrieval floods against the Clinical Guideline RAG Corpus, saturating retrieval capacity and preventing the Diagnostic Agent from accessing clinical guidelines.
D-12	Medical Literature Vector Index	LOW	An attacker may flood the Medical Literature Vector Index with excessive retrieval queries, degrading vector search availability for the Treatment Planner Agent.

L3 — Agent Framework (31 findings)

ID	Component	Severity	Threat
S-6	Supervisor Orchestrator	CRITICAL	An attacker may impersonate the Supervisor Orchestrator to issue unauthorized delegation commands to specialist agents, bypassing orchestration controls and routing fabricated clinical tasks.
T-7	Clinical MCP Tool Server	CRITICAL	An attacker who compromises the Clinical MCP Tool Server may tamper with FHIR read/write operations, modifying patient records without authorization or returning corrupted data to agents.
I-7	Clinical MCP Tool Server	CRITICAL	The Clinical MCP Tool Server may expose PHI from FHIR read operations to unauthorized agents through insufficient access controls on tool results, or through overly broad FHIR queries returning more data than requested.
E-7	Clinical MCP Tool Server	CRITICAL	A compromised agent may exploit the Clinical MCP Tool Server to escalate FHIR access beyond the calling agent's authorized scope, performing privileged FHIR operations (e.g., bulk data export, schema modifications) not authorized for the requesting agent.
AG-1	Supervisor Orchestrator	CRITICAL	The Supervisor Orchestrator may autonomously execute consequential clinical delegation commands without adequate human oversight, routing clinical tasks based on AI-generated orchestration logic that bypasses physician review or RBAC compliance checks.
AG-2	Supervisor Orchestrator	CRITICAL	A compromised Supervisor Orchestrator may abuse its privileged position as the delegation authority to issue unauthorized tool calls or FHIR operations through specialist agents, circumventing per-agent access controls by delegating to agents with broader permissions.
AG-7	Clinical MCP Tool Server	CRITICAL	A malicious or compromised agent may exploit the Clinical MCP Tool Server to perform privilege escalation via tool chaining — executing a sequence of individually-permitted FHIR operations that collectively achieves an unauthorized outcome (e.g., bulk patient data export or unauthorized record modification).
S-7	Diagnostic Agent	HIGH	An attacker may spoof the Diagnostic Agent's identity to inject fraudulent diagnostic results into the Inter-Agent Communication Channel, polluting the treatment planning process.

S-8	Treatment Planner Agent	HIGH	An attacker may spoof Treatment Planner Agent responses to inject malicious treatment plans into the inter-agent coordination flow.
S-9	Clinical MCP Tool Server	HIGH	An attacker may spoof the Clinical MCP Tool Server to return malicious tool results to Diagnostic Agent or Treatment Planner Agent, corrupting clinical decision inputs.
T-4	Supervisor Orchestrator	HIGH	An attacker who compromises the Supervisor Orchestrator may tamper with the delegation logic, routing clinical tasks to adversary-controlled specialist implementations or corrupting aggregated outputs before returning them to the portal.
T-5	Diagnostic Agent	HIGH	An attacker may tamper with the Diagnostic Agent's tool call requests to Clinical MCP Tool Server, injecting malicious FHIR operations or corrupting guideline retrieval queries.
T-6	Treatment Planner Agent	HIGH	An attacker may tamper with the Treatment Planner Agent's literature retrieval queries or tool calls, injecting adversarially crafted inputs that corrupt treatment plan generation.
R-6	Supervisor Orchestrator	HIGH	The Supervisor Orchestrator may fail to maintain non-repudiable records of which delegation commands it issued and which specialist results it aggregated, making agent accountability impossible.
R-9	Clinical MCP Tool Server	HIGH	The Clinical MCP Tool Server may fail to maintain non-repudiable records of which FHIR operations were executed in response to agent tool calls, making it impossible to trace patient record modifications to their source.
I-4	Supervisor Orchestrator	HIGH	The Supervisor Orchestrator aggregates sensitive patient data from FHIR, specialist results, and model outputs. A compromise may expose this aggregated clinical context, which is more sensitive than any individual component's data.
I-5	Diagnostic Agent	HIGH	The Diagnostic Agent may expose sensitive patient context retrieved from Clinical Guideline RAG Corpus and risk stratification results through tool call parameters, error responses, or insufficient isolation between patient sessions.
I-6	Treatment Planner Agent	HIGH	The Treatment Planner Agent may disclose sensitive patient data retrieved from the Medical Literature Vector Index through insufficient session isolation or unfiltered error responses.
D-4	Supervisor Orchestrator	HIGH	An attacker who compromises one specialist agent may flood the Supervisor Orchestrator with high-volume task results or error responses, causing resource exhaustion that renders the orchestrator unable to coordinate legitimate clinical queries.
D-5	Diagnostic Agent	HIGH	An attacker may target the Diagnostic Agent with resource-exhausting tool call floods or retrieval storms against the Clinical Guideline RAG Corpus, disrupting diagnostic capabilities for legitimate clinical queries.
D-7	Clinical MCP Tool Server	HIGH	An attacker who compromises an agent may flood the Clinical MCP Tool Server with excessive JSON-RPC tool calls or FHIR operations, exhausting server resources and denying tool access to legitimate agents.
E-4	Supervisor Orchestrator	HIGH	A compromised Supervisor Orchestrator may escalate its own privilege to bypass RBAC checks enforced by the HIPAA Policy Engine, or grant escalated permissions to specialist agents beyond their authorized scope.
E-5	Diagnostic Agent	HIGH	A compromised Diagnostic Agent may escalate beyond its authorized scope by issuing FHIR operations that exceed its

			data access permissions via the Clinical MCP Tool Server, accessing patient records outside the current clinical query.
E-6	Treatment Planner Agent	HIGH	A compromised Treatment Planner Agent may escalate its access to FHIR resources beyond the current patient's authorized scope through the Clinical MCP Tool Server.
AG-3	Diagnostic Agent	HIGH	The Diagnostic Agent may autonomously execute FHIR write operations via the Clinical MCP Tool Server beyond its authorized clinical scope, persisting adversarial or erroneous diagnostic data to patient records without physician authorization.
AG-4	Diagnostic Agent	HIGH	A compromised Diagnostic Agent may abuse the Clinical MCP Tool Server as a tool abuse vector, issuing malicious FHIR operations (bulk reads, unauthorized writes) that exceed the agent's authorized scope.
AG-5	Treatment Planner Agent	HIGH	The Treatment Planner Agent may autonomously incorporate adversarially retrieved medical literature into treatment plans without human validation, resulting in dangerous or contraindicated treatment recommendations delivered to physicians.
AG-6	Treatment Planner Agent	HIGH	A compromised Treatment Planner Agent may abuse the Clinical MCP Tool Server to perform unauthorized FHIR operations, writing false treatment prescriptions or accessing patient records outside the current patient scope.
R-7	Diagnostic Agent	MEDIUM	The Diagnostic Agent may deny issuing specific tool calls to the Clinical MCP Tool Server or deny the guideline retrieval queries it submitted, preventing investigation of erroneous diagnoses.
R-8	Treatment Planner Agent	MEDIUM	The Treatment Planner Agent may deny issuing specific literature retrieval queries or tool calls that contributed to harmful treatment plans, obstructing clinical accountability.
D-6	Treatment Planner Agent	MEDIUM	An attacker may exhaust Treatment Planner Agent resources through oversized literature retrieval queries or excessive tool call sequences, disrupting treatment planning for legitimate patients.

L4 — Deployment Infrastructure (9 findings)

ID	Component	Severity	Threat
T-14	EHR Ingestion Queue	HIGH	An attacker may tamper with EHR update events in the ingestion queue before normalization, injecting false patient data that propagates into the FHIR Resource Store.
I-14	EHR Ingestion Queue	HIGH	Patient EHR update events in the ingestion queue may be disclosed through insufficient queue access controls, allowing unauthorized parties to read enqueued patient records.
D-13	Model Inference API Gateway	HIGH	An attacker may saturate the Model Inference API Gateway through request floods, denying inference access to all agents dependent on foundation model capabilities.
S-12	Model Inference API Gateway	MEDIUM	An attacker may spoof the Model Inference API Gateway to intercept inference requests and return fabricated completions, bypassing the real foundation models.
T-13	Model Inference API Gateway	MEDIUM	An attacker may tamper with the Model Inference API Gateway configuration, rerouting inference requests to adversary-controlled model endpoints or modifying prompts before forwarding.
R-12	Model Inference API Gateway	MEDIUM	The Model Inference API Gateway may fail to maintain non-repudiable records of all inference requests forwarded to

			foundation models, making it impossible to reconstruct the chain of clinical AI decisions.
I-13	Model Inference API Gateway	MEDIUM	The Model Inference API Gateway may expose inference request logs containing patient PHI or clinical context through insufficient log access controls or log retention policies.
D-14	EHR Ingestion Queue	MEDIUM	An attacker may flood the EHR Ingestion Queue with malformed or oversized EHR events, causing queue saturation and blocking legitimate patient record ingestion.
E-10	Model Inference API Gateway	MEDIUM	An attacker who compromises the Model Inference API Gateway may escalate to access inference endpoints for models not authorized for the requesting agent, circumventing model-level access controls.

L5 — Evaluation and Observability (6 findings)

ID	Component	Severity	Threat
T-16	Outcomes Telemetry and Physician Override Audit Store	CRITICAL	An attacker may tamper with the Outcomes Telemetry and Physician Override Audit Store, injecting adversarial physician-override signals that corrupt the learning loop re-training process and cause model drift toward attacker-preferred outputs.
T-15	Clinical Audit Log	HIGH	An attacker who gains write access to the Clinical Audit Log may tamper with decision log entries, covering tracks for unauthorized actions or injecting false audit evidence.
I-15	Clinical Audit Log	HIGH	The Clinical Audit Log accumulates highly sensitive clinical decision trails. Unauthorized read access could disclose PHI, clinical reasoning, and agent decision patterns to adversaries.
I-16	Outcomes Telemetry and Physician Override Audit Store	HIGH	Physician override telemetry may contain implicit patient data. Unauthorized access to the Outcomes Telemetry store could disclose sensitive clinical patterns or be used for re-identification of de-identified training data.
D-15	Clinical Audit Log	MEDIUM	An attacker may flood the Clinical Audit Log with excessive log entries, causing disk exhaustion that prevents legitimate audit log writes and destroys accountability coverage.
D-16	Outcomes Telemetry and Physician Override Audit Store	MEDIUM	An attacker may flood the Outcomes Telemetry store with spurious override signals, degrading the learning loop's ability to incorporate legitimate physician feedback and corrupting model re-training.

L6 — Security and Compliance (11 findings)

ID	Component	Severity	Threat
S-13	HIPAA RBAC + Policy Engine	MEDIUM	An attacker may spoof the HIPAA RBAC + Policy Engine to issue false access-grant decisions to the Physician Clinical Portal, enabling unauthorized clinical data access.
S-14	Consent and De-identification Guardrail	MEDIUM	An attacker may spoof the Consent and De-identification Guardrail response, returning raw PHI to components that expected de-identified data, bypassing consent enforcement.
T-17	HIPAA RBAC + Policy Engine	MEDIUM	An attacker may tamper with RBAC policy rules in the policy engine, granting unauthorized access to clinical data or escalating privileges for compromised accounts.

T-18	Consent and De-identification Guardrail	MEDIUM	An attacker may tamper with the de-identification guardrail configuration, disabling or weakening de-identification rules to expose raw PHI to downstream components.
R-13	HIPAA RBAC + Policy Engine	MEDIUM	The HIPAA RBAC + Policy Engine may fail to maintain non-repudiable records of all access decisions, preventing post-incident review of which access grants were issued to which entities.
I-18	Consent and De-identification Guardrail	MEDIUM	The Consent and De-identification Guardrail may disclose raw PHI through implementation flaws in the de-identification process, or expose de-identification rule logic that enables re-identification attacks.
D-17	HIPAA RBAC + Policy Engine	MEDIUM	An attacker may flood the HIPAA RBAC + Policy Engine with access decision requests, causing policy engine unavailability and potentially blocking all clinical data access during the outage.
D-18	Consent and De-identification Guardrail	MEDIUM	An attacker may flood the Consent and De-identification Guardrail with PHI processing requests, saturating de-identification capacity and blocking access to patient records for legitimate clinical workflows.
E-11	HIPAA RBAC + Policy Engine	MEDIUM	An attacker who exploits a vulnerability in the HIPAA RBAC + Policy Engine may escalate to administrative access, modifying policy rules to grant themselves or other entities unauthorized clinical data access.
E-12	Consent and De-identification Guardrail	MEDIUM	An attacker who compromises the Consent and De-identification Guardrail may escalate to bypass consent enforcement, accessing raw PHI without the patient's consent for unauthorized clinical or research purposes.
I-17	HIPAA RBAC + Policy Engine	LOW	The HIPAA RBAC + Policy Engine may leak access control policies through detailed error messages or API responses, enabling attackers to enumerate permissions and plan privilege escalation.

L7 — Agent Ecosystem (23 findings)

ID	Component	Severity	Threat
S-1	Physician	CRITICAL	An attacker may impersonate a legitimate physician by replaying or forging clinical query credentials, gaining unauthorized access to clinical recommendation views and patient data.
S-5	Inter-Agent Communication Channel	CRITICAL	An attacker who gains access to the inter-agent message bus may spoof supervisor delegation messages, causing specialist agents to act on forged orchestration commands.
T-3	Inter-Agent Communication Channel	CRITICAL	An attacker with access to the inter-agent message bus may tamper with delegation messages or specialist results in transit, corrupting clinical reasoning across the multi-agent pipeline.
I-3	Inter-Agent Communication Channel	CRITICAL	Sensitive clinical context including patient PHI and clinical reasoning may be disclosed through the inter-agent message bus if messages are transmitted without encryption or if channel access is insufficiently restricted.
S-2	Patient	HIGH	An attacker may submit fraudulent EHR update events by spoofing a patient identity, injecting false patient records into the ingestion pipeline.
S-3	Physician Clinical Portal	HIGH	An attacker may spoof the Physician Clinical Portal to intercept clinical recommendation responses from the

			Supervisor Orchestrator, receiving sensitive patient data intended for legitimate physicians.
T-1	Physician Clinical Portal	HIGH	An attacker may tamper with clinical recommendation responses in transit between Supervisor Orchestrator and the Physician Clinical Portal, altering displayed recommendations without physician awareness.
T-2	Patient Summary Generator	HIGH	An attacker with access to the summary generation pipeline may tamper with patient-facing summaries, injecting dangerous or false clinical guidance into patient communications.
R-5	Inter-Agent Communication Channel	HIGH	The Inter-Agent Communication Channel may fail to provide non-repudiable records of all delegation messages and specialist results, allowing agents to deny actions taken during the coordination flow.
I-1	Physician Clinical Portal	HIGH	Sensitive clinical recommendation data including patient PHI may be disclosed through the Physician Clinical Portal via insecure HTTPS configuration, excessive error messages, or missing access controls on recommendation views.
I-2	Patient Summary Generator	HIGH	Patient-facing summaries may inadvertently include sensitive clinical details beyond the authorized disclosure scope, or may be delivered to wrong patients due to missing identity validation.
D-1	Physician Clinical Portal	HIGH	An attacker may flood the Physician Clinical Portal with clinical query requests, degrading availability for legitimate physicians during critical clinical decision periods.
D-3	Inter-Agent Communication Channel	HIGH	An attacker may flood the Inter-Agent Communication Channel with spurious delegation messages, starving legitimate specialist agent task processing and disrupting the multi-agent coordination flow.
E-1	Physician Clinical Portal	HIGH	An attacker who gains access to a low-privilege physician session may escalate to access clinical data belonging to other physicians or patients by exploiting broken access controls in the portal's recommendation view logic.
E-2	Patient Summary Generator	HIGH	An attacker may exploit the Patient Summary Generator to request summaries for patients other than the authorized recipient, escalating access to unauthorized patient records.
E-3	Inter-Agent Communication Channel	HIGH	An attacker who compromises the Inter-Agent Communication Channel may escalate channel access to issue supervisor-level delegation commands to specialist agents, bypassing the Supervisor Orchestrator's authority and performing unauthorized clinical operations.
AG-8	Inter-Agent Communication Channel	HIGH	A compromised or rogue agent may abuse the Inter-Agent Communication Channel to flood specialist agents with excessive delegation messages, executing a resource exhaustion attack that disrupts multi-agent coordination across all clinical sessions.
S-4	Patient Summary Generator	MEDIUM	An attacker may spoof the Patient Summary Generator endpoint to intercept patient-facing summaries containing sensitive clinical recommendations.
R-1	Physician	MEDIUM	A physician may deny issuing a clinical query or claim that a recommendation view they acted upon was different from what the system recorded, creating liability disputes.
R-3	Physician Clinical Portal	MEDIUM	The Physician Clinical Portal may fail to provide non-repudiable records of which clinical recommendations were displayed to a physician, making it impossible to reconstruct the basis for a physician's clinical decision.

D-2	Patient Summary Generator	MEDIUM	An attacker may flood the Patient Summary Generator with spurious summary requests, degrading availability for legitimate patient summary delivery.
R-2	Patient	LOW	A patient may deny submitting EHR update events that were used as the basis for clinical decisions, complicating audit trails.
R-4	Patient Summary Generator	LOW	The Patient Summary Generator may fail to maintain non-repudiable records of summaries delivered to patients, creating gaps in clinical accountability.

107 findings across 7 MAESTRO layers | Sorted by severity (critical first)

Detailed Findings

Findings Detail — Residual Risk

Findings Detail — Residual Risk

HIGH S-1

Physician

Attacker replays or forges clinical query credentials

Implement multi-factor authentication (MFA) and credential replay protection for the physician authentication endpoint. Deploy a short-lived JWT or OAuth 2.0 token scheme with cryptographic binding to session context. Add token replay detection using a nonce or jti claim validated against a server-side token store.

Residual: 8.4 | Control: No Control Found

HIGH S-2

Patient

Attacker submits fraudulent EHR update events

Implement patient identity verification with signed event envelopes on the EHR ingestion endpoint. Each incoming EHR update event should carry a verifiable patient identity token (e.g., SMART on FHIR patient context) and a message authentication code preventing tampering. Deploy input schema validation to reject malformed or unexpected event structures.

Residual: 7.4 | Control: No Control Found

HIGH D-1

Physician Clinical Portal

Attacker floods portal with clinical query requests

Implement request rate limiting on the physician clinical portal API endpoints. Configure a per-IP and per-session rate limiter with thresholds calibrated to expected clinical usage patterns. Add a circuit breaker wrapping the downstream CDSS orchestration layer to prevent cascade failures under load.

Residual: 7.1 | Control: No Control Found

HIGH E-1

Physician Clinical Portal

Attacker escalates from low-privilege session

Implement role-based access control (RBAC) enforcing per-physician data scope on all portal data retrieval endpoints. Add resource ownership validation that prevents horizontal privilege escalation to other physicians' or patients' data. Every data fetch endpoint must assert that the requesting session's physician ID matches the requested resource scope.

Residual: 7.0 | Control: No Control Found

HIGH S-5

Inter-Agent Communication Channel

Attacker spoofs supervisor delegation messages

Implement message authentication on the inter-agent communication channel. Each delegation message must carry a cryptographic signature from the originating supervisor agent, verified by the receiving specialist agent before execution. Use a shared asymmetric key infrastructure where the supervisor holds the private signing key and specialist agents hold the corresponding verification key.

Residual: 7.0 | Control: No Control Found

HIGH T-3

Inter-Agent Communication Channel

Attacker tampers with delegation messages in transit

Implement message integrity protection on all inter-agent delegation messages and specialist results. Encrypt the message bus channel using TLS with mutual authentication, and add per-message HMAC integrity tokens that detect tampering in transit. Log all message integrity failures to the clinical audit log.

Residual: 7.0 | Control: No Control Found

MEDIUM AG-8

Inter-Agent Communication Channel

Compromised agent abuses inter-agent channel

Implement per-agent message quotas and channel-level rate limiting to prevent resource exhaustion by a compromised agent. Each agent instance should have a configurable message-per-second budget on the inter-agent bus. Deploy a circuit breaker that isolates an agent flooding the channel, preventing cascade to downstream specialist agents.

Residual: 6.8 | Control: No Control Found

MEDIUM D-3

Inter-Agent Communication Channel

Delegation message flood starves specialist agents

Implement channel-level message rate limiting and backpressure on the inter-agent delegation bus. Set maximum delegation message ingestion rates and queue depth limits. Add message priority queuing so clinical-critical delegation messages are processed ahead of non-urgent agent coordination traffic.

Residual: 6.8 | Control: No Control Found

MEDIUM E-2

Patient Summary Generator

Attacker exploits summary generator for unauthorized patients

Implement patient-scope authorization on the Patient Summary Generator. All summary requests must be validated against the requesting session's authorized patient list. Add an ABAC policy check verifying that the requestor has an active care relationship with the requested patient before generating the summary.

Residual: 6.8 | Control: No Control Found

MEDIUM **AGP-01**

Inter-Agent Communication Channel

Multi-agent coordination creates potential for coordinated action

Implement behavioral monitoring for coordinated agent activity patterns. Deploy a cross-agent telemetry aggregator that detects statistical anomalies in multi-agent coordination (synchronized message timing, unusual delegation fan-out, correlated output deviations across specialist agents). Trigger human-in-the-loop review when collusion indicators are detected.

Residual: 6.7 | Control: No Control Found

MEDIUM **E-8**

Clinical LLM

Prompt injection causes elevated reasoning authority

Implement prompt input validation and output sanitization for the Clinical LLM inference endpoint. Add a prompt injection detection layer that scans input for known injection patterns before forwarding to the model. Enforce strict output schema validation to detect anomalous reasoning responses that deviate from expected clinical recommendation formats.

Residual: 6.6 | Control: No Control Found

MEDIUM **E-3**

Inter-Agent Communication Channel

Compromised channel escalates to supervisor-level authority

Implement least-privilege access controls on the inter-agent communication channel. Each agent should only be able to send message types appropriate to its role (specialist agents cannot send delegation messages; only the supervisor can initiate delegation). Enforce role-based message type restrictions at the bus level.

Residual: 6.6 | Control: No Control Found

MEDIUM **T-8**

Clinical LLM

Attacker tampers with prompt inputs forwarded by API Gateway

Implement request signing and integrity verification on prompts forwarded by the Model Inference API Gateway to the Clinical LLM. The gateway must attest that the prompt content has not been modified in transit from the originating agent. Add an HMAC on each prompt payload that the LLM endpoint verifies before processing.

Residual: 6.5 | Control: No Control Found

MEDIUM **I-3**

Inter-Agent Communication Channel

PHI disclosed through unencrypted inter-agent channel

Implement end-to-end encryption on the inter-agent communication channel for all messages containing PHI. Enforce TLS 1.3 on the transport layer and add application-layer field-level encryption for patient identifiers and clinical data payloads within delegation messages.

Residual: 6.4 | Control: No Control Found

MEDIUM E-7

Clinical MCP Tool Server

Compromised agent escalates to unauthorized FHIR operations

Implement tool-call authorization on the Clinical MCP Tool Server. All FHIR tool operations must be authorized against the requesting agent's permitted tool scope. Add a policy engine that validates tool call intent (operation type, resource type, patient scope) against the agent's declared role before executing.

Residual: 6.4 | Control: No Control Found

MEDIUM S-6

Supervisor Orchestrator

Attacker impersonates Supervisor Orchestrator

Implement cryptographic identity verification for the Supervisor Orchestrator. The orchestrator must present a verifiable identity credential (signed JWT or mutual TLS certificate) when establishing connections with specialist agents and when receiving connections from external components. Specialist agents must verify orchestrator identity before accepting delegation messages.

Residual: 6.4 | Control: No Control Found

MEDIUM D-13

Model Inference API Gateway

Request floods saturate inference gateway

Implement request rate limiting and adaptive throttling on the Model Inference API Gateway. Configure per-caller rate limits, total inference concurrency caps, and request queue depth limits. Add a circuit breaker that drops non-urgent inference requests when the gateway approaches capacity saturation.

Residual: 6.2 | Control: No Control Found

MEDIUM AG-7

Clinical MCP Tool Server

Tool chaining achieves unauthorized FHIR output

|

Residual: 6.2 | Control: No Control Found

MEDIUM T-7

Clinical MCP Tool Server

Compromised MCP Tool Server tampers with FHIR operations

|

Residual: 6.2 | Control: No Control Found

MEDIUM D-2

Patient Summary Generator

Spurious summary requests flood Patient Summary Generator

|

Residual: 6.2 | Control: No Control Found

MEDIUM AG-2

Supervisor Orchestrator

Compromised orchestrator abuses delegation authority

| Implement delegation authority limits on the Supervisor Orchestrator. The orchestrator's delegation permissions should be defined at deployment time and enforced at runtime — the orchestrator cannot grant capabilities it does not possess. Add a human-in-the-loop checkpoint for high-impact clinical delegations (e.g., treatment recommendations above a risk threshold).

Residual: 6.1 | Control: No Control Found

MEDIUM D-17

HIPAA RBAC + Policy Engine

RBAC request flood causes policy engine unavailability

|

Residual: 6.1 | Control: No Control Found

MEDIUM I-1

Physician Clinical Portal

PHI disclosed via insecure HTTPS config or error messages

| Enforce HTTPS with HSTS on the Physician Clinical Portal and configure Content Security Policy to prevent information leakage through error responses. Implement generic error handling that does not expose PHI or stack traces. Add X-Content-Type-Options, X-Frame-Options, and Referrer-Policy headers.

Residual: 6.1 | Control: No Control Found

MEDIUM LLM-4

Risk Stratification Model

Adversarial patient records manipulate risk scores

| Implement adversarial input detection for the Risk Stratification Model. Add a pre-inference validation layer that checks incoming patient record feature vectors for statistical anomalies indicative of adversarial perturbation. Log detected anomalies and route suspicious inputs for human review rather than automated risk stratification.

Residual: 6.1 | Control: No Control Found

MEDIUM T-10

FHIR Resource Store

Attacker tampers with patient records

Implement write integrity controls on the FHIR Resource Store. All patient record write operations must be authorized via the RBAC policy engine and logged to the immutable clinical audit log. Add optimistic locking (ETag/version-based) on FHIR resources to detect concurrent modification attacks.

Residual: 6.1 | Control: No Control Found

MEDIUM T-11

Clinical Guideline RAG Corpus

Attacker poisons RAG corpus adversarially

Implement content integrity verification for the Clinical Guideline RAG Corpus. All documents added to the corpus must be cryptographically hashed on ingestion and periodically re-verified. Add provenance metadata tracking source, timestamp, and ingestion authority for each document chunk. Deploy anomaly detection on embedding distributions to detect injected adversarial content.

Residual: 5.5 | Control: No Control Found

MEDIUM LLM-5

Risk Stratification Model

Fine-tuning poisoning

|

Residual: 5.5 | Control: No Control Found

MEDIUM T-16

Outcomes Telemetry and Physician Override Audit Store

Attacker injects adversarial override signals

|

Residual: 5.5 | Control: No Control Found

MEDIUM T-17

HIPAA RBAC + Policy Engine

Attacker tampers with RBAC policy rules

Implement change control and integrity verification for RBAC policy rules. All policy changes must be authorized through a workflow requiring approval from an authorized administrator, logged to an immutable audit log, and cryptographically signed. Deploy policy version control with rollback capability.

Residual: 5.5 | Control: No Control Found

MEDIUM E-11

HIPAA RBAC + Policy Engine

Attacker exploits RBAC vulnerability to admin escalation

Harden the HIPAA RBAC Policy Engine against privilege escalation by implementing strict separation of duties: no single role should be able to both modify policies and hold admin-level permissions. Add immutable policy evaluation logging and enforce defense-in-depth with secondary authorization checks on sensitive operations.

Residual: 5.5 | Control: No Control Found

MEDIUM E-12

Consent and De-identification Guardrail

Attacker bypasses consent enforcement

Implement multi-layer consent enforcement with a defense-in-depth approach. The guardrail should not be a single bypass-able gate. Add secondary consent verification at the data layer and implement tamper-evident consent records that are cryptographically linked to the patient identity.

Residual: 5.5 | Control: No Control Found

MEDIUM T-2

Patient Summary Generator

Attacker tampers with patient-facing summaries

I

Residual: 5.5 | Control: No Control Found

MEDIUM T-13

Model Inference API Gateway

Attacker tampers with API Gateway configuration

I

Residual: 5.5 | Control: No Control Found

MEDIUM S-3

Physician Clinical Portal

Attacker spoofs portal to intercept clinical data

I

Residual: 5.6 | Control: No Control Found

MEDIUM T-5

Diagnostic Agent

Attacker tampers with Diagnostic Agent tool calls

I

Residual: 5.6 | Control: No Control Found

MEDIUM T-6

Treatment Planner Agent

Attacker tampers with Treatment Planner Agent

■

Residual: 5.6 | Control: No Control Found

MEDIUM AG-5

Treatment Planner Agent

Treatment Planner Agent incorporates adversarial context

■

Residual: 5.6 | Control: No Control Found

MEDIUM E-10

Model Inference API Gateway

Compromised API Gateway escalates to access inference models

■

Residual: 5.6 | Control: No Control Found

MEDIUM S-7

Diagnostic Agent

Attacker spoofs Diagnostic Agent to inject false findings

■

Residual: 5.9 | Control: No Control Found

MEDIUM S-8

Treatment Planner Agent

Attacker spoofs Treatment Planner Agent responses

■

Residual: 5.9 | Control: No Control Found

MEDIUM S-9

Clinical MCP Tool Server

Attacker spoofs MCP Tool Server to return malicious data

■

Residual: 5.9 | Control: No Control Found

MEDIUM E-5

Diagnostic Agent

Compromised Diagnostic Agent escalates to unauthorized operations

|

Residual: 5.9 | Control: No Control Found

MEDIUM E-6

Treatment Planner Agent

Compromised Treatment Planner Agent escalates privileges

|

Residual: 5.9 | Control: No Control Found

MEDIUM R-1

Physician

Physician denies issuing clinical query

| Implement immutable audit logging for all physician clinical queries. Each query must be logged with a cryptographically non-repudiable record including physician identity (authenticated session token hash), query parameters, timestamp, and response identifiers. Store audit logs in an append-only log store that cannot be modified by the physician or clinical portal application.

Residual: 5.9 | Control: No Control Found

MEDIUM R-2

Patient

Patient denies submitting EHR update events

|

Residual: 5.9 | Control: No Control Found

MEDIUM AG-3

Diagnostic Agent

Diagnostic Agent autonomously executes unauthorized actions

|

Residual: 5.8 | Control: No Control Found

MEDIUM E-4

Supervisor Orchestrator

Compromised orchestrator escalates to bypass delegation

|

Residual: 5.8 | Control: No Control Found

MEDIUM E-9

Risk Stratification Model

Adversarially manipulated risk scores trigger unintended actions

■

Residual: 5.8 | Control: No Control Found

MEDIUM T-4

Supervisor Orchestrator

Compromised orchestrator tampers with delegation

■

Residual: 5.8 | Control: No Control Found

MEDIUM I-2

Patient Summary Generator

Patient summaries include unauthorized PHI

■

Residual: 5.8 | Control: No Control Found

MEDIUM AGP-03

Supervisor Orchestrator

Multi-agent cascading delegation exhibits emergent behavior

■ Implement delegation depth limits and cycle detection on the Supervisor Orchestrator to prevent emergent cascading delegation behaviors. Set a maximum delegation depth (e.g., 3 hops) and enforce it at runtime. Add monitoring for unexpected delegation fan-out patterns that may indicate emergent coordination.

Residual: 5.7 | Control: No Control Found

MEDIUM AG-4

Diagnostic Agent

Compromised Diagnostic Agent abuses MCP Tool Server

■

Residual: 5.7 | Control: No Control Found

MEDIUM AG-6

Treatment Planner Agent

Compromised Treatment Planner Agent abuses MCP Tool Server

■

Residual: 5.7 | Control: No Control Found

MEDIUM D-8

Clinical LLM

Large prompt floods exhaust Clinical LLM inference capacity

|

Residual: 5.7 | Control: No Control Found

MEDIUM R-5

Inter-Agent Communication Channel

Channel fails non-repudiable records of delegation

|

Implement non-repudiable message logging for all inter-agent delegation messages. Each delegation and response must be logged with the sending agent's cryptographic signature in an append-only audit log. The log must be independent of the agent bus so that a compromised channel cannot erase its own audit trail.

Residual: 5.7 | Control: No Control Found

MEDIUM AG-1

Supervisor Orchestrator

Autonomous delegation bypasses human oversight

|

Residual: 5.0 | Control: No Control Found

MEDIUM R-6

Supervisor Orchestrator

Orchestrator fails non-repudiable records of decisions

|

Residual: 5.0 | Control: No Control Found

MEDIUM I-10

FHIR Resource Store

Patient PHI disclosed via unauthorized FHIR query

|

Residual: 5.4 | Control: No Control Found

MEDIUM D-4

Supervisor Orchestrator

High-volume task result flood causes orchestrator failure

|

Residual: 5.4 | Control: No Control Found

MEDIUM **D-5**

Diagnostic Agent

Tool call floods disrupt Diagnostic Agent

■

Residual: 5.4 | Control: No Control Found

MEDIUM **D-7**

Clinical MCP Tool Server

Excessive JSON-RPC calls exhaust MCP server resources

■

Residual: 5.4 | Control: No Control Found

MEDIUM **D-10**

FHIR Resource Store

FHIR query floods degrade patient record availability

■

Residual: 5.4 | Control: No Control Found

MEDIUM **S-4**

Patient Summary Generator

Attacker spoofs Patient Summary Generator

■

Residual: 5.3 | Control: No Control Found

MEDIUM **AGP-02**

Outcomes Telemetry and Physician Override Audit Store

Persistent-state learning loop enables temporal attack

■ Implement temporal integrity controls on the learning loop feedback pathway. Validate that override signals in the telemetry store are consistent with contemporaneous clinical events (timestamp validation, signal provenance verification). Add rate limiting on override signal ingestion to prevent flooding the learning loop with adversarial signals.

Residual: 5.3 | Control: No Control Found

MEDIUM **I-7**

Clinical MCP Tool Server

PHI exposed to unauthorized agents via MCP

■

Residual: 5.3 | Control: No Control Found

MEDIUM LLM-1

Clinical LLM

Clinical LLM PHI exposure

■

Residual: 5.3 | Control: No Control Found

MEDIUM T-12

Medical Literature Vector Index

Attacker injects malicious vector embeddings

■

Residual: 5.3 | Control: No Control Found

MEDIUM T-14

EHR Ingestion Queue

Attacker tampers with EHR events in ingestion queue

■

Residual: 5.3 | Control: No Control Found

MEDIUM T-1

Physician Clinical Portal

Attacker tampers with clinical recommendations

■

Residual: 5.2 | Control: No Control Found

MEDIUM D-15

Clinical Audit Log

Excessive log entries cause disk exhaustion

■

Residual: 5.2 | Control: No Control Found

MEDIUM D-18

Consent and De-identification Guardrail

PHI processing flood saturates de-id capacity

■

Residual: 5.2 | Control: No Control Found

MEDIUM I-8

Clinical LLM

Clinical LLM surfaces PHI from training data

I

Residual: 5.1 | Control: No Control Found

MEDIUM I-9

Risk Stratification Model

Risk model leaks patient cohort data

I

Residual: 5.1 | Control: No Control Found

MEDIUM LLM-6

Risk Stratification Model

Membership inference attack violates patient privacy

I

Residual: 5.1 | Control: No Control Found

MEDIUM I-5

Diagnostic Agent

Diagnostic Agent exposes patient context

I

Residual: 4.9 | Control: No Control Found

MEDIUM I-6

Treatment Planner Agent

Treatment Planner Agent discloses patient data

I

Residual: 4.9 | Control: No Control Found

MEDIUM I-14

EHR Ingestion Queue

EHR update events in queue disclosed

I

Residual: 4.9 | Control: No Control Found

MEDIUM I-15

Clinical Audit Log

Unauthorized audit log read discloses sensitive data

I

Residual: 4.9 | Control: No Control Found

MEDIUM I-16

Outcomes Telemetry and Physician Override Audit Store

Telemetry access discloses clinical patterns

I

Residual: 4.9 | Control: No Control Found

MEDIUM R-3

Physician Clinical Portal

Portal fails non-repudiable recommendation records

I

Residual: 4.8 | Control: No Control Found

MEDIUM R-4

Patient Summary Generator

Summary Generator fails non-repudiable records

I

Residual: 4.8 | Control: No Control Found

MEDIUM R-9

Clinical MCP Tool Server

MCP Tool Server fails non-repudiable FHIR records

I

Residual: 4.8 | Control: No Control Found

MEDIUM T-15

Clinical Audit Log

Attacker tampers with audit log entries

I

Residual: 4.8 | Control: No Control Found

MEDIUM I-17

HIPAA RBAC + Policy Engine

RBAC engine leaks access control policies

I

Residual: 4.8 | Control: No Control Found

MEDIUM LLM-3

Clinical LLM

Adversary extracts Clinical LLM knowledge

I

Residual: 4.8 | Control: No Control Found

MEDIUM D-16

Outcomes Telemetry and Physician Override Audit Store

Spurious override signals degrade learning loop

I

Residual: 4.7 | Control: No Control Found

MEDIUM LLM-2

Clinical LLM

Adversary poisons training data via learning loop

I

Residual: 4.7 | Control: No Control Found

MEDIUM R-13

HIPAA RBAC + Policy Engine

RBAC engine fails non-repudiable access decisions

I

Residual: 4.7 | Control: No Control Found

MEDIUM D-9

Risk Stratification Model

High-volume risk inference requests saturate model

I

Residual: 4.6 | Control: No Control Found

MEDIUM D-6

Treatment Planner Agent

Oversized retrieval queries exhaust Treatment Planner

I

Residual: 4.6 | Control: No Control Found

MEDIUM D-11

Clinical Guideline RAG Corpus

Retrieval floods saturate RAG Corpus capacity

I

Residual: 4.6 | Control: No Control Found

MEDIUM D-12

Medical Literature Vector Index

Excessive retrieval queries degrade Vector Index

I

Residual: 4.6 | Control: No Control Found

MEDIUM D-14

EHR Ingestion Queue

Malformed EHR events cause queue saturation

I

Residual: 4.6 | Control: No Control Found

MEDIUM I-4

Supervisor Orchestrator

Compromise exposes aggregated sensitive patient data

I

Residual: 4.3 | Control: No Control Found

MEDIUM I-13

Model Inference API Gateway

API Gateway exposes inference request logs

I

Residual: 4.2 | Control: No Control Found

MEDIUM S-14

Consent and De-identification Guardrail

Attacker spoofs guardrail returning raw PHI

■

Residual: 4.2 | Control: No Control Found

MEDIUM T-9

Risk Stratification Model

Attacker tampers with fine-tuning data

■

Residual: 4.2 | Control: No Control Found

MEDIUM I-18

Consent and De-identification Guardrail

Guardrail discloses raw PHI through de-identification failure

■

Residual: 4.5 | Control: No Control Found

MEDIUM S-10

Clinical LLM

Attacker spoofs Clinical LLM completion responses

■

Residual: 4.5 | Control: No Control Found

MEDIUM S-11

Risk Stratification Model

Attacker spoofs Risk Stratification Model output

■

Residual: 4.5 | Control: No Control Found

MEDIUM S-12

Model Inference API Gateway

Attacker spoofs API Gateway to return fabricated responses

■

Residual: 4.5 | Control: No Control Found

MEDIUM S-13

HIPAA RBAC + Policy Engine

Attacker spoofs RBAC engine to issue false authorization

■

Residual: 4.5 | Control: No Control Found

MEDIUM T-18

Consent and De-identification Guardrail

Attacker tampers with de-identification configuration

■

Residual: 4.5 | Control: No Control Found

MEDIUM R-7

Diagnostic Agent

Diagnostic Agent denies issuing tool calls

■

Residual: 4.1 | Control: No Control Found

MEDIUM R-8

Treatment Planner Agent

Treatment Planner Agent denies tool calls

■

Residual: 4.1 | Control: No Control Found

MEDIUM R-10

Clinical LLM

Clinical LLM fails non-repudiable prompt-completion records

■

Residual: 4.1 | Control: No Control Found

MEDIUM R-11

Risk Stratification Model

Risk model fails non-repudiable inference records

■

Residual: 4.1 | Control: No Control Found

MEDIUM R-12

Model Inference API Gateway

API Gateway fails non-repudiable inference records

I

Residual: 4.1 | Control: No Control Found

LOW I-11

Clinical Guideline RAG Corpus

RAG Corpus inadvertently indexes patient data

Implement PHI detection and prevention controls on the RAG corpus ingestion pipeline. Screen all documents before indexing to detect and redact any incidentally included patient data. Add an automated PHI scanner (NER-based) as a pre-ingestion gate.

Residual: 3.7 | Control: No Control Found

LOW I-12

Medical Literature Vector Index

Vector Index exposes research data

Implement access controls and namespace isolation on the Medical Literature Vector Index. Research literature should be stored in a separate namespace from patient-adjacent data. Add read authorization checks on vector search queries to prevent cross-namespace data leakage.

Residual: 3.7 | Control: No Control Found

110 findings | Sorted by residual severity (critical first)

Control Coverage

Control Status by STRIDE Category

STRIDE Category	Found	Partial	Missing	Total
Spoofing	0	0	14	14
Tampering	0	0	18	18
Repudiation	0	0	13	13
Information Disclosure	0	0	18	18
Denial of Service	0	0	18	18
Elevation of Privilege	0	0	12	12
Agentic Threats	0	0	8	8
LLM Threats	0	0	6	6
Other	0	0	3	3

Coverage Summary

Control Status	Count	Percentage
Control Found	0	0%
Partial Control	0	0%
No Control Found	108	100%
Total	108	100%

Remediation Roadmap

■ Critical: 0 ■ High: 6 ■ Medium: 102 ■ Low: 2

110 total actions

Priority	Finding	Recommendation	SLA	Status
HIGH 6 actions				
S-1	Attacker replays or forges clinical query credentials	Implement multi-factor authentication (MFA) and credential replay protection for the physician authentication endpoint. Deploy a short-lived JWT or OAuth 2.0 token scheme with cryptographic binding to session context. Add token replay detection using a nonce or jti claim validated against a server-side token store.	14d	No Control Found
S-2	Attacker submits fraudulent EHR update events	Implement patient identity verification with signed event envelopes on the EHR ingestion endpoint. Each incoming EHR update event should carry a verifiable patient identity token (e.g., SMART on FHIR patient context) and a message authentication code preventing tampering. Deploy input schema validation to reject malformed or unexpected event structures.	14d	No Control Found
D-1	Attacker floods portal with clinical query requests	Implement request rate limiting on the physician clinical portal API endpoints. Configure a per-IP and per-session rate limiter with thresholds calibrated to expected clinical usage patterns. Add a circuit breaker wrapping the downstream CDSS orchestration layer to prevent cascade failures under load.	14d	No Control Found
E-1	Attacker escalates from low-privilege session	Implement role-based access control (RBAC) enforcing per-physician data scope on all portal data retrieval endpoints. Add resource ownership validation that prevents horizontal privilege escalation to other physicians' or patients' data. Every data fetch endpoint must assert that the requesting session's physician ID matches the requested resource scope.	14d	No Control Found
S-5	Attacker spoofs supervisor delegation messages	Implement message authentication on the inter-agent communication channel. Each delegation message must carry a cryptographic signature from the originating supervisor agent, verified by the receiving specialist agent before execution. Use a shared asymmetric key infrastructure where the supervisor holds the private signing key	14d	No Control Found

Priority	Finding	Recommendation	SLA	Status
		and specialist agents hold the corresponding verification key.		
T-3	Attacker tampers with delegation messages in transit	Implement message integrity protection on all inter-agent delegation messages and specialist results. Encrypt the message bus channel using TLS with mutual authentication, and add per-message HMAC integrity tokens that detect tampering in transit. Log all message integrity failures to the clinical audit log.	14d	No Control Found
MEDIUM				
102 actions				
AG-8	Compromised agent abuses inter-agent channel	Implement per-agent message quotas and channel-level rate limiting to prevent resource exhaustion by a compromised agent. Each agent instance should have a configurable message-per-second budget on the inter-agent bus. Deploy a circuit breaker that isolates an agent flooding the channel, preventing cascade to downstream specialist agents.	30d	No Control Found
D-3	Delegation message flood starves specialist agents	Implement channel-level message rate limiting and backpressure on the inter-agent delegation bus. Set maximum delegation message ingestion rates and queue depth limits. Add message priority queuing so clinical-critical delegation messages are processed ahead of non-urgent agent coordination traffic.	30d	No Control Found
E-2	Attacker exploits summary generator for unauthorized patients	Implement patient-scope authorization on the Patient Summary Generator. All summary requests must be validated against the requesting session's authorized patient list. Add an ABAC policy check verifying that the requestor has an active care relationship with the requested patient before generating the summary.	30d	No Control Found
AGP-01	Multi-agent coordination creates potential for coordinated action	Implement behavioral monitoring for coordinated agent activity patterns. Deploy a cross-agent telemetry aggregator that detects statistical anomalies in multi-agent coordination (synchronized message timing, unusual delegation fan-out, correlated output deviations across specialist agents). Trigger human-in-the-loop review when collusion indicators are detected.	30d	No Control Found
E-8	Prompt injection causes elevated reasoning authority	Implement prompt input validation and output sanitization for the Clinical LLM inference endpoint. Add a prompt injection detection layer that scans input for known injection patterns before forwarding to the model. Enforce strict output schema	30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
		validation to detect anomalous reasoning responses that deviate from expected clinical recommendation formats.		
E-3	Compromised channel escalates to supervisor-level authority	Implement least-privilege access controls on the inter-agent communication channel. Each agent should only be able to send message types appropriate to its role (specialist agents cannot send delegation messages; only the supervisor can initiate delegation). Enforce role-based message type restrictions at the bus level.	30d	No Control Found
T-8	Attacker tampers with prompt inputs forwarded by API Gateway	Implement request signing and integrity verification on prompts forwarded by the Model Inference API Gateway to the Clinical LLM. The gateway must attest that the prompt content has not been modified in transit from the originating agent. Add an HMAC on each prompt payload that the LLM endpoint verifies before processing.	30d	No Control Found
I-3	PHI disclosed through unencrypted inter-agent channel	Implement end-to-end encryption on the inter-agent communication channel for all messages containing PHI. Enforce TLS 1.3 on the transport layer and add application-layer field-level encryption for patient identifiers and clinical data payloads within delegation messages.	30d	No Control Found
E-7	Compromised agent escalates to unauthorized FHIR operations	Implement tool-call authorization on the Clinical MCP Tool Server. All FHIR tool operations must be authorized against the requesting agent's permitted tool scope. Add a policy engine that validates tool call intent (operation type, resource type, patient scope) against the agent's declared role before executing.	30d	No Control Found
S-6	Attacker impersonates Supervisor Orchestrator	Implement cryptographic identity verification for the Supervisor Orchestrator. The orchestrator must present a verifiable identity credential (signed JWT or mutual TLS certificate) when establishing connections with specialist agents and when receiving connections from external components. Specialist agents must verify orchestrator identity before accepting delegation messages.	30d	No Control Found
D-13	Request floods saturate inference gateway	Implement request rate limiting and adaptive throttling on the Model Inference API Gateway. Configure per-caller rate limits, total inference concurrency caps, and request queue depth limits. Add a circuit breaker that drops non-urgent inference requests when the gateway approaches capacity saturation.	30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
AG-7	Tool chaining achieves unauthorized FHIR output		30d	No Control Found
T-7	Compromised MCP Tool Server tampers with FHIR operations		30d	No Control Found
D-2	Spurious summary requests flood Patient Summary Generator		30d	No Control Found
AG-2	Compromised orchestrator abuses delegation authority	Implement delegation authority limits on the Supervisor Orchestrator. The orchestrator's delegation permissions should be defined at deployment time and enforced at runtime — the orchestrator cannot grant capabilities it does not possess. Add a human-in-the-loop checkpoint for high-impact clinical delegations (e.g., treatment recommendations above a risk threshold).	30d	No Control Found
D-17	RBAC request flood causes policy engine unavailability		30d	No Control Found
I-1	PHI disclosed via insecure HTTPS config or error messages	Enforce HTTPS with HSTS on the Physician Clinical Portal and configure Content Security Policy to prevent information leakage through error responses. Implement generic error handling that does not expose PHI or stack traces. Add X-Content-Type-Options, X-Frame-Options, and Referrer-Policy headers.	30d	No Control Found
LLM-4	Adversarial patient records manipulate risk scores	Implement adversarial input detection for the Risk Stratification Model. Add a pre-inference validation layer that checks incoming patient record feature vectors for statistical anomalies indicative of adversarial perturbation. Log detected anomalies and route suspicious inputs for human review rather than automated risk stratification.	30d	No Control Found
T-10	Attacker tampers with patient records	Implement write integrity controls on the FHIR Resource Store. All patient record write operations must be authorized via the RBAC policy engine and logged to the immutable clinical audit log. Add optimistic locking (ETag/version-based) on FHIR resources to detect concurrent modification attacks.	30d	No Control Found
T-11	Attacker poisons RAG corpus adversarially	Implement content integrity verification for the Clinical Guideline RAG Corpus. All documents added to the corpus must be cryptographically hashed on ingestion and periodically re-verified. Add provenance metadata tracking source, timestamp, and ingestion authority for each document chunk. Deploy anomaly detection on	30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
		embedding distributions to detect injected adversarial content.		
LLM-5	Fine-tuning poisoning		30d	No Control Found
T-16	Attacker injects adversarial override signals		30d	No Control Found
T-17	Attacker tampers with RBAC policy rules	Implement change control and integrity verification for RBAC policy rules. All policy changes must be authorized through a workflow requiring approval from an authorized administrator, logged to an immutable audit log, and cryptographically signed. Deploy policy version control with rollback capability.	30d	No Control Found
E-11	Attacker exploits RBAC vulnerability to admin escalation	Harden the HIPAA RBAC Policy Engine against privilege escalation by implementing strict separation of duties: no single role should be able to both modify policies and hold admin-level permissions. Add immutable policy evaluation logging and enforce defense-in-depth with secondary authorization checks on sensitive operations.	30d	No Control Found
E-12	Attacker bypasses consent enforcement	Implement multi-layer consent enforcement with a defense-in-depth approach. The guardrail should not be a single bypass-able gate. Add secondary consent verification at the data layer and implement tamper-evident consent records that are cryptographically linked to the patient identity.	30d	No Control Found
T-2	Attacker tampers with patient-facing summaries		30d	No Control Found
T-13	Attacker tampers with API Gateway configuration		30d	No Control Found
S-3	Attacker spoofs portal to intercept clinical data		30d	No Control Found
T-5	Attacker tampers with Diagnostic Agent tool calls		30d	No Control Found
T-6	Attacker tampers with Treatment Planner Agent		30d	No Control Found
AG-5	Treatment Planner Agent incorporates adversarial context		30d	No Control Found
E-10	Compromised API Gateway escalates to access inference models		30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
S-7	Attacker spoofs Diagnostic Agent to inject false findings		30d	No Control Found
S-8	Attacker spoofs Treatment Planner Agent responses		30d	No Control Found
S-9	Attacker spoofs MCP Tool Server to return malicious data		30d	No Control Found
E-5	Compromised Diagnostic Agent escalates to unauthorized operations		30d	No Control Found
E-6	Compromised Treatment Planner Agent escalates privileges		30d	No Control Found
R-1	Physician denies issuing clinical query	Implement immutable audit logging for all physician clinical queries. Each query must be logged with a cryptographically non-repudiable record including physician identity (authenticated session token hash), query parameters, timestamp, and response identifiers. Store audit logs in an append-only log store that cannot be modified by the physician or clinical portal application.	30d	No Control Found
R-2	Patient denies submitting EHR update events		30d	No Control Found
AG-3	Diagnostic Agent autonomously executes unauthorized actions		30d	No Control Found
E-4	Compromised orchestrator escalates to bypass delegation		30d	No Control Found
E-9	Adversarially manipulated risk scores trigger unintended actions		30d	No Control Found
T-4	Compromised orchestrator tampers with delegation		30d	No Control Found
I-2	Patient summaries include unauthorized PHI		30d	No Control Found
AGP-03	Multi-agent cascading delegation exhibits emergent behavior	Implement delegation depth limits and cycle detection on the Supervisor Orchestrator to prevent emergent cascading delegation behaviors. Set a maximum delegation depth (e.g., 3 hops) and enforce it at runtime. Add monitoring for unexpected delegation fan-	30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
		out patterns that may indicate emergent coordination.		
AG-4	Compromised Diagnostic Agent abuses MCP Tool Server		30d	No Control Found
AG-6	Compromised Treatment Planner Agent abuses MCP Tool Server		30d	No Control Found
D-8	Large prompt floods exhaust Clinical LLM inference capacity		30d	No Control Found
R-5	Channel fails non-repudiable records of delegation	Implement non-repudiable message logging for all inter-agent delegation messages. Each delegation and response must be logged with the sending agent's cryptographic signature in an append-only audit log. The log must be independent of the agent bus so that a compromised channel cannot erase its own audit trail.	30d	No Control Found
AG-1	Autonomous delegation bypasses human oversight		30d	No Control Found
R-6	Orchestrator fails non-repudiable records of decisions		30d	No Control Found
I-10	Patient PHI disclosed via unauthorized FHIR query		30d	No Control Found
D-4	High-volume task result flood causes orchestrator failure		30d	No Control Found
D-5	Tool call floods disrupt Diagnostic Agent		30d	No Control Found
D-7	Excessive JSON-RPC calls exhaust MCP server resources		30d	No Control Found
D-10	FHIR query floods degrade patient record availability		30d	No Control Found
S-4	Attacker spoofs Patient Summary Generator		30d	No Control Found
AGP-02	Persistent-state learning loop enables temporal attack	Implement temporal integrity controls on the learning loop feedback pathway. Validate that override signals in the telemetry store are consistent with contemporaneous clinical events (timestamp validation, signal provenance verification). Add rate limiting on override signal ingestion to prevent	30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
		flooding the learning loop with adversarial signals.		
I-7	PHI exposed to unauthorized agents via MCP		30d	No Control Found
LLM-1	Clinical LLM PHI exposure		30d	No Control Found
T-12	Attacker injects malicious vector embeddings		30d	No Control Found
T-14	Attacker tampers with EHR events in ingestion queue		30d	No Control Found
T-1	Attacker tampers with clinical recommendations		30d	No Control Found
D-15	Excessive log entries cause disk exhaustion		30d	No Control Found
D-18	PHI processing flood saturates de-id capacity		30d	No Control Found
I-8	Clinical LLM surfaces PHI from training data		30d	No Control Found
I-9	Risk model leaks patient cohort data		30d	No Control Found
LLM-6	Membership inference attack violates patient privacy		30d	No Control Found
I-5	Diagnostic Agent exposes patient context		30d	No Control Found
I-6	Treatment Planner Agent discloses patient data		30d	No Control Found
I-14	EHR update events in queue disclosed		30d	No Control Found
I-15	Unauthorized audit log read discloses sensitive data		30d	No Control Found
I-16	Telemetry access discloses clinical patterns		30d	No Control Found
R-3	Portal fails non-repudiable recommendation records		30d	No Control Found
R-4	Summary Generator fails non-repudiable records		30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
R-9	MCP Tool Server fails non-repudiable FHIR records		30d	No Control Found
T-15	Attacker tampers with audit log entries		30d	No Control Found
I-17	RBAC engine leaks access control policies		30d	No Control Found
LLM-3	Adversary extracts Clinical LLM knowledge		30d	No Control Found
D-16	Spurious override signals degrade learning loop		30d	No Control Found
LLM-2	Adversary poisons training data via learning loop		30d	No Control Found
R-13	RBAC engine fails non-repudiable access decisions		30d	No Control Found
D-9	High-volume risk inference requests saturate model		30d	No Control Found
D-6	Oversized retrieval queries exhaust Treatment Planner		30d	No Control Found
D-11	Retrieval floods saturate RAG Corpus capacity		30d	No Control Found
D-12	Excessive retrieval queries degrade Vector Index		30d	No Control Found
D-14	Malformed EHR events cause queue saturation		30d	No Control Found
I-4	Compromise exposes aggregated sensitive patient data		30d	No Control Found
I-13	API Gateway exposes inference request logs		30d	No Control Found
S-14	Attacker spoofs guardrail returning raw PHI		30d	No Control Found
T-9	Attacker tampers with fine-tuning data		30d	No Control Found
I-18	Guardrail discloses raw PHI through de-identification failure		30d	No Control Found
S-10	Attacker spoofs Clinical LLM completion responses		30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
S-11	Attacker spoofs Risk Stratification Model output		30d	No Control Found
S-12	Attacker spoofs API Gateway to return fabricated responses		30d	No Control Found
S-13	Attacker spoofs RBAC engine to issue false authorization		30d	No Control Found
T-18	Attacker tampers with de-identification configuration		30d	No Control Found
R-7	Diagnostic Agent denies issuing tool calls		30d	No Control Found
R-8	Treatment Planner Agent denies tool calls		30d	No Control Found
R-10	Clinical LLM fails non-repudiable prompt-completion records		30d	No Control Found
R-11	Risk model fails non-repudiable inference records		30d	No Control Found
R-12	API Gateway fails non-repudiable inference records		30d	No Control Found
LOW 2 actions				
I-11	RAG Corpus inadvertently indexes patient data	Implement PHI detection and prevention controls on the RAG corpus ingestion pipeline. Screen all documents before indexing to detect and redact any incidentally included patient data. Add an automated PHI scanner (NER-based) as a pre-ingestion gate.	90d	No Control Found
I-12	Vector Index exposes research data	Implement access controls and namespace isolation on the Medical Literature Vector Index. Research literature should be stored in a separate namespace from patient-adjacent data. Add read authorization checks on vector search queries to prevent cross-namespace data leakage.	90d	No Control Found